هم‌رسان: نسخه‌های بین‌سازمانی و سازمانی

گزارش کار، توضیح سازوکار و الگوریتم‌ها، و وضعیت آزمون‌ها · نسخهٔ ۳٫۲ سند · ۱۴۰۵/۰۷/۲۵ (نسخهٔ ۳٫۱: ۱۴۰۵/۰۷/۱۵)

تازه در نسخهٔ ۳٫۲ (۱۴۰۵/۰۷/۲۵): پاسخ به نقد تیم محصول و منتور که «با هر عضو تازه باید به همه فایل برسد، و وقتی اینترنت قطع است و فقط پیامک کار می‌کند این ممکن نیست».

- **گواهی عضو:** هر فایل کلید یک گواهی ۱۰۳ بایتی دارد که مرجع امضا کرده است: «این کلید مال این شمارهٔ همراه است». گوشی‌ها گواهی را با اولین بستهٔ کانال امن برای هم می‌فرستند. پس **عضو تازه فقط فایل خودش را لازم دارد** و هیچ گوشی دیگری فایل تازه نمی‌خواهد (بخش‌های ۶-۲ و ۹-۷).
- **کانال امن ۴ تکه:** درخواست و پاسخ هر کدام ۲ تکه پیامک (پیش‌تر ۱۰ و ۱۱). در آزمون دو گوشی واقعی پیام اول حدود ۷ ثانیه بعد از «ارسال» رفت (پیش‌تر ۵۰ ثانیه). لایهٔ پساکوانتومی بلافاصله بعد، در پس‌زمینه، با ۲۲ تکه اضافه می‌شود.
- **هزینهٔ آگاهانه:** چند پیام اولِ پیش از تمام شدن ارتقا فقط با رمزنگاری کلاسیک محافظت می‌شوند؛ گواهی فقط با Ed25519 امضا می‌شود؛ گواهی **انقضا و ابطال ندارد** (تصمیم مالک پروژه). جزئیات در بخش ۱۷.
- **قفل برنامه:** باز کردن با اثر انگشت یا چهره، پنهان شدن محتوای اعلان‌ها فقط وقتی برنامه قفل است، «رمز برای پاسخ به تماس» و قانون‌های مسدود کردن تماس (بخش ۱۳).
- **پنل صدور ۱٫۲:** گواهی در همهٔ فایل‌ها، و برای پوشهٔ مرجع آزمایشی قدیمی، ساختن دوبارهٔ فایل همه با گواهی در اولین باز شدن.

این سند برای کسی نوشته شده که هم‌رسان را ندیده است: مدیر محصول، کارشناس امنیت، منتور پروژه یا هر کس دیگری که باید تصمیم بگیرد. هر جا اسم یک الگوریتم یا اصطلاح فنی آمده، همان‌جا با زبان ساده گفته‌ایم چیست و چرا انتخاب شده است. یک واژه‌نامه هم در انتهای سند هست.

اگر فقط می‌خواهید بدانید با برنامه چطور کار کنید، سند جداگانهٔ «راهنمای کاربر نسخهٔ بین‌سازمانی» را بخوانید. آنجا همهٔ مراحل با تصویرهای دو گوشی واقعی آمده است.

فهرست

۱. هم‌رسان چیست
۲. سه نسخه و تفاوتشان
۳. کد فعال‌سازی نسخهٔ بین‌سازمانی
۴. رمزنگاری به زبان ساده
۵. الگوریتم‌هایی که به کار رفته و چرا
۶. مسیر یک پیام رمز از نوشتن تا خوانده شدن
۷. اپراتور و برنامه‌های دیگر چه می‌بینند
۸. بخش امن
۹. بانک کلید و فایل کلید
۱۰. پوشهٔ مرجع کلید (Hamresan-Authority)
۱۱. پیام رمز گروهی
۱۲. دفترچهٔ تلفن مخفی
۱۳. قابلیت‌های امنیتی دیگر
۱۴. نقشهٔ استفاده از برنامه، با تصویر
۱۵. تطبیق با پیوست فنی
۱۶. آزمون‌ها
۱۷. محدودیت‌ها و تصمیم‌های باز
۱۸. واژه‌نامه

۱. هم‌رسان چیست

هم‌رسان یک برنامهٔ اندرویدی فارسی است که سه کار اصلی گوشی را یک‌جا انجام می‌دهد: **پیامک**، **تماس تلفنی** و **دفترچهٔ تلفن**. کاربر آن را به‌جای برنامهٔ پیامک و برنامهٔ تلفن خود گوشی انتخاب می‌کند. در نسخهٔ معمولی، هم‌رسان یک پیام‌رسان و شماره‌گیر کامل است و همهٔ کارهای روزمره را انجام می‌دهد.

نسخه‌های امن هم‌رسان یک کار دیگر هم می‌کنند: **پیامک را رمز می‌کنند**. یعنی دو نفری که هر دو هم‌رسان امن دارند، می‌توانند از طریق همان پیامک معمولی اپراتور پیامی بفرستند که هیچ‌کس جز خودشان نتواند بخواند. اپراتور، کسی که سیم‌کارت را شنود می‌کند و برنامه‌های دیگر گوشی فقط یک رشتهٔ نامفهوم می‌بینند.

چرا پیامک و نه اینترنت؟ پیامک بدون اینترنت کار می‌کند و در اختلال یا قطع اینترنت هم از کار نمی‌افتد. به سرور هم نیاز ندارد، پس سروری نیست که از کار بیفتد، هک شود یا اطلاعات کسی را نگه دارد. پیام مستقیم از سیم‌کارت یک نفر به سیم‌کارت نفر دیگر می‌رود.

۲. سه نسخه و تفاوتشان

کد برنامه یکی است، اما سه نسخه از آن ساخته می‌شود که در قالب **دو فایل نصبی** (APK) عرضه می‌شوند:

نسخه	از کجا نصب می‌شود	چه فرقی دارد
تجاری	فروشگاه‌ها (بازار، مایکت)	پیامک، تماس و مخاطبین معمولی. هیچ قابلیت امنی ندارد و پیام رمز نه می‌فرستد و نه می‌خواند.
بین‌سازمانی	همان فایل تجاری؛ با **کد فعال‌سازی** داخل برنامه باز می‌شود	همهٔ قابلیت‌های امن: بخش امن، پیام رمز، گروه رمز، دفترچهٔ مخفی و بقیه. مناسب ارتباط بین چند سازمان.
سازمانی	فایل نصبی جداگانه، فقط توزیع مستقیم و هرگز در فروشگاه	همهٔ قابلیت‌های بین‌سازمانی، بدون نیاز به کد فعال‌سازی، به‌علاوهٔ «متن پوششی» (بخش ۱۳). گزارش خطا هم از این نسخه کاملاً حذف شده تا با هیچ سرور بیرونی تماس نگیرد.

- **هر دو فایل شناسهٔ یکسان دارند** (`ir.hamrasan.app`) و با یک کلید امضا ساخته می‌شوند. اندروید آن‌ها را یک برنامه می‌بیند. پس اگر کسی نسخهٔ سازمانی را روی نسخهٔ تجاری نصب کند، اطلاعاتش از بین نمی‌رود.
- **فروشگاه نسخهٔ سازمانی را با نسخهٔ عادی عوض نمی‌کند.** هر برنامهٔ اندرویدی یک شمارهٔ نسخهٔ داخلی دارد (versionCode) و فروشگاه فقط وقتی به‌روزرسانی پیشنهاد می‌دهد که شمارهٔ خودش بزرگ‌تر باشد. شمارهٔ نسخهٔ سازمانی از دو میلیارد شروع می‌شود (`2,000,000,000 + N`) و نسخهٔ فروشگاهی عددی کوچک است. پس هیچ‌وقت «به‌روزرسانی» فروشگاه روی نسخهٔ سازمانی نصب نمی‌شود. این را روی گوشی امتحان کردیم و اندروید نصب را رد کرد.
- اسکریپت ساخت نسخهٔ نهایی بعد از ساخت فایل دوباره بررسی می‌کند که شناسه، شمارهٔ نسخه و امضا درست باشند و کلید آزمایشی داخل فایل نرفته باشد.

۳. کد فعال‌سازی نسخهٔ بین‌سازمانی

نسخهٔ بین‌سازمانی همان فایل فروشگاهی است. برای اینکه قابلیت‌های امن روی هر گوشی فقط با اجازه باز شود، برنامه یک **کد فعال‌سازی ۱۰ نویسه‌ای** می‌خواهد که مخصوص همان گوشی است. کد روی گوشی دیگر کار نمی‌کند. برای ساختنش هم اینترنت و سرور لازم نیست.

قالب این کد عیناً همان قالب نرم‌افزار قبلی منتور است (S2MS، فایل Activation.java)، تا برنامهٔ ویندوزی تولید کد بدون تغییر کار کند.

۳-۱. مراحل، قدم به قدم

۱. شناسهٔ یکتای گوشی
اندروید به هر برنامه روی هر گوشی یک شناسهٔ ۱۶ نویسه‌ای می‌دهد به نام ANDROID_ID. این شناسه برای هر گوشی فرق دارد و با بازگشت به تنظیمات کارخانه عوض می‌شود. برنامه آن را به کسی نشان نمی‌دهد.

۲. کد دستگاه (۶ نویسه)
برنامه از شناسه با الگوریتم BLAKE3 یک «اثر انگشت» می‌سازد و ۳ بایت اولش را به شکل ۶ نویسهٔ هگز (۰ تا ۹ و a تا f) نمایش می‌دهد. نمونه: `4ccd9c`

۳. ترکیب با شناسهٔ برنامه
نویسه‌های کد دستگاه یکی‌درمیان با شناسهٔ ثابت برنامه، یعنی `111111`، کنار هم چیده می‌شوند و یک رشتهٔ ۱۲ نویسه‌ای می‌سازند: `41c1c1d191c1`

۴. کد فعال‌سازی (۱۰ نویسه)
از این رشته دوباره اثر انگشت BLAKE3 گرفته می‌شود و ۵ بایت اولش، یعنی ۱۰ نویسهٔ هگز، کد فعال‌سازی است: `585982eaf4`

کاربر کد دستگاه را تلفنی یا حضوری به پشتیبانی می‌گوید. پشتیبانی آن را در برنامهٔ ویندوزی وارد می‌کند و کد فعال‌سازی را می‌گیرد. کاربر کد را در گوشی وارد می‌کند. گوشی همان محاسبه را خودش انجام می‌دهد و اگر دو نتیجه یکی بود، نسخهٔ بین‌سازمانی باز می‌شود.

نمونه	کد دستگاه	رشتهٔ ترکیبی	کد فعال‌سازی
گوشی شیائومی آزمون	`4ccd9c`	`41c1c1d191c1`	`585982eaf4`
نمونهٔ مرجع برای آزمون برنامهٔ ویندوزی	`b60966`	`b16101916161`	`9c4a48e93a`

۳-۲. چند نکتهٔ کاربردی

- مسیر در برنامه: تنظیمات ← «درباره برنامه» ← «نسخه بین‌سازمانی». این گزینه فقط در فایل فروشگاهی هست، چون نسخهٔ سازمانی به کد نیاز ندارد.
- هنگام وارد کردن کد، بزرگی و کوچکی حروف، فاصله، خط تیره و ارقام فارسی اهمیتی ندارد. کد اشتباه با پیام «کد فعال‌سازی درست نیست» رد می‌شود.
- برنامه هر بار که باز می‌شود کد ذخیره‌شده را دوباره با همان گوشی بررسی می‌کند. اگر اطلاعات برنامه به گوشی دیگری منتقل شود یا گوشی به تنظیمات کارخانه برگردد، نسخه دیگر فعال نیست.
- «غیرفعال کردن» برنامه را به نسخهٔ تجاری برمی‌گرداند. **محتوای بخش امن پاک نمی‌شود** و با وارد کردن دوبارهٔ همان کد همه چیز برمی‌گردد. این را روی گوشی امتحان کردیم.

چرا BLAKE3؟ چون نرم‌افزار قبلی و برنامهٔ ویندوزی منتور از همین الگوریتم استفاده می‌کردند و قرار بود سازگار بمانیم. BLAKE3 یک تابع هش استاندارد و سریع است (بخش ۴ می‌گوید تابع هش چیست).

محدودیت این روش: کل روش ساخت کد داخل فایل نصبی است. کسی که فایل را مهندسی معکوس کند می‌تواند برای هر گوشی کد بسازد. کد هم قابل باطل کردن نیست، چون سروری وجود ندارد. این روش جلوی استفادهٔ عادی و بی‌اجازه را می‌گیرد، اما در برابر یک متخصص مقاوم نیست. **امنیت پیام‌ها به این کد وابسته نیست.** کسی که کد فعال‌سازی جعل کند، باز هم بدون فایل کلید سازمان نمی‌تواند پیام رمز کسی را بخواند یا به نام کسی پیام بفرستد. راه محکم‌تر کد امضاشده است که در بخش ۱۷ آمده.

۴. رمزنگاری به زبان ساده

این بخش برای کسی است که با رمزنگاری آشنا نیست. بقیهٔ سند بر همین چند مفهوم بنا شده است.

۴-۱. رمزنگاری متقارن: یک کلید برای قفل و باز کردن

> **مثال:** یک صندوق که با یک کلید هم قفل می‌شود و هم باز. هر کس کلید را دارد، می‌تواند هم چیزی داخلش بگذارد و هم بیرون بیاورد.

در رمزنگاری متقارن، فرستنده و گیرنده **یک کلید مشترک** دارند. سریع است و برای رمز کردن خود متن پیام عالی است. هم‌رسان برای این کار AES-256 را به کار می‌برد. مشکل اینجاست که این کلید مشترک اول باید به دست هر دو طرف برسد. اگر کلید را با پیامک بفرستیم، اپراتور هم آن را می‌بیند.

۴-۲. رمزنگاری نامتقارن: کلید عمومی و کلید خصوصی

> **مثال:** صندوق پستی جلوی خانه. شکاف صندوق برای همه باز است و هر کس می‌تواند نامه داخلش بیندازد. این همان **کلید عمومی** است. اما فقط صاحب‌خانه کلید در صندوق را دارد و می‌تواند نامه‌ها را بیرون بیاورد. این همان **کلید خصوصی** است.

در رمزنگاری نامتقارن، هر نفر یک **جفت‌کلید** دارد: کلید عمومی که به همه داده می‌شود و کلید خصوصی که هرگز از گوشی خودش بیرون نمی‌رود. با کلید عمومی یک نفر می‌توان چیزی ساخت که فقط کلید خصوصی همان نفر بازش می‌کند. پس دو نفر بدون اینکه قبلاً رازی را رد و بدل کرده باشند، می‌توانند به یک کلید مشترک برسند. این کار «توافق کلید» نام دارد.

هم‌رسان هر دو روش را با هم به کار می‌برد، مثل همهٔ سامانه‌های امن امروزی. با رمزنگاری نامتقارن یک کلید مشترک ساخته می‌شود و با رمزنگاری متقارن متن پیام‌ها رمز می‌شود. اولی مشکل رساندن کلید را حل می‌کند و دومی سریع و کم‌حجم است.

۴-۳. امضای دیجیتال: مهری که جعل نمی‌شود

> **مثال:** مهر و امضای مدیر پای یک نامهٔ رسمی. هر کس نمونهٔ امضا را دیده باشد، می‌تواند تشخیص دهد امضا اصل است، اما فقط خود مدیر می‌تواند آن را بزند. در امضای دیجیتال، اگر حتی یک حرف نامه بعد از امضا عوض شود، امضا دیگر معتبر نیست.

در هم‌رسان، «مرجع کلید» سازمان فهرست اعضا و کلیدهایشان را امضا می‌کند. برنامهٔ روی گوشی فقط کلید عمومی مرجع را دارد. با آن می‌تواند امضا را بررسی کند، ولی نمی‌تواند امضای تازه بسازد. پس اگر کسی فایل کلید جعلی بسازد یا یک کلید را در فهرست عوض کند، برنامه آن را رد می‌کند.

۴-۴. تابع هش: اثر انگشت داده

تابع هش از هر داده‌ای، کوچک یا بزرگ، یک عدد کوتاه با طول ثابت می‌سازد. اگر یک بیت از داده عوض شود، نتیجه کاملاً فرق می‌کند. از نتیجه هم نمی‌شود به داده رسید. هم‌رسان از هش برای شناسهٔ کلیدها، کد دستگاه، کد گروه و بررسی سالم بودن فایل‌ها استفاده می‌کند (SHA-256 و BLAKE3).

۴-۵. کامپیوتر کوانتومی و رمزنگاری «پساکوانتومی»

رمزنگاری نامتقارنی که امروز همه جا هست (مثل RSA و منحنی‌های بیضوی، از جمله X25519) بر مسائل ریاضی‌ای تکیه دارد که برای کامپیوترهای معمولی تقریباً حل‌نشدنی‌اند. یک کامپیوتر کوانتومی به اندازهٔ کافی بزرگ این مسائل را سریع حل می‌کند. چنین

کامپیوتری هنوز ساخته نشده، اما خطر واقعی امروز این است: **کسی پیامک‌های رمز را همین حالا ضبط کند و چند سال بعد که کامپیوتر کوانتومی آمد، آن‌ها را باز کند**. پیامک‌ها از مسیر اپراتور می‌گذرند و ضبط کردنشان کار سختی نیست.

الگوریتم‌های «پساکوانتومی» بر مسائل ریاضی دیگری تکیه دارند که در برابر کامپیوتر کوانتومی هم سخت می‌مانند. مؤسسهٔ استاندارد آمریکا (NIST) در سال ۲۰۲۴ پس از هشت سال مسابقه و بررسی عمومی، این الگوریتم‌ها را استاندارد کرد. هم‌رسان دو تا از آن‌ها را به کار می‌برد: ML-KEM برای توافق کلید و ML-DSA برای امضا.

۶-۴. چرا «ترکیبی»؟

الگوریتم‌های پساکوانتومی جدیدند. هنوز آن‌قدر سابقه ندارند که مطمئن باشیم هیچ ضعف ریاضی یا خطای پیاده‌سازی در آن‌ها پیدا نمی‌شود. الگوریتم‌های کلاسیک برعکس، سال‌ها آزموده شده‌اند اما در برابر کامپیوتر کوانتومی آسیب‌پذیرند. هم‌رسان هر دو را **با هم** به کار می‌برد: کلید پیام از هر دو ساخته می‌شود و امضا فقط وقتی معتبر است که هر دو امضا درست باشند. برای شکستن پیام، مهاجم باید **هر دو** را بشکند. این همان رویکردی است که سیگنال، کروم و iMessage اپل هم در پیش گرفته‌اند.

۵. الگوریتم‌هایی که به کار رفته و چرا

هیچ الگوریتمی برای هم‌رسان اختراع نشده است. در رمزنگاری، الگوریتم ساخت خودمان تقریباً همیشه ضعیف‌تر از الگوریتم‌های استانداردی است که سال‌ها زیر ذره‌بین متخصصان دنیا بوده‌اند. همهٔ الگوریتم‌ها استاندارد هستند و پیاده‌سازی آن‌ها از کتابخانهٔ متن‌باز و شناخته‌شدهٔ Bouncy Castle (نسخهٔ ۱٫۸۶) و کتابخانه‌های خود اندروید است. همه با بردارهای آزمون رسمی NIST و RFC آزموده شده‌اند.

الگوریتم	نوع	در هم‌رسان کجا	چرا این
ML-KEM-768 FIPS 203	نامتقارن، پساکوانتومی	ارتقای پساکوانتومی کانال امن در پس‌زمینه (بخش ۶-۲)؛ مهروموم کردن رخدادهای دفترچهٔ مخفی	استاندارد پساکوانتومی NIST برای توافق کلید. سطح ۷۶۸ امنیتی معادل AES-192 دارد و حجمش (کلید عمومی ۱۱۸۴ بایت) هنوز در چند پیامک جا می‌شود.
X25519 RFC 7748	نامتقارن، کلاسیک	به‌تنهایی در کانال امن ۴ تکه‌ای با گواهی (سه ترکیب، به سبک Noise XX)؛ کنار ML-KEM در کانال کامل و در ارتقا	نیمهٔ کلاسیک طرح ترکیبی. سال‌ها در TLS، سیگنال و SSH به کار رفته و کلیدش فقط ۳۲ بایت است.
ML-DSA-65 FIPS 204	امضا، پساکوانتومی	امضای مرجع روی دفترچهٔ سازمان	استاندارد پساکوانتومی NIST برای امضا. امضا روی فایل کلید است، نه روی هر پیامک، پس حجم ۳۳۰۹ بایتی‌اش مشکلی ایجاد نمی‌کند.
Ed25519 RFC 8032	امضا، کلاسیک	کنار ML-DSA روی دفترچهٔ سازمان؛ **به‌تنهایی** روی گواهی عضو	نیمهٔ کلاسیک امضای ترکیبی. سریع، کوتاه (۶۴ بایت) و بسیار آزموده. گواهی عضو در هر کانال تازه با پیامک فرستاده می‌شود؛ امضای ML-DSA (۳۳۰۹ بایت) آن را به حدود ۳۰ تکه می‌رساند، پس گواهی فقط با Ed25519 امضا می‌شود.
AES-256-GCM	متقارن	رمز کردن متن هر پیام، فایل کلید و کلید بخش امن	استاندارد جهانی رمز متقارن. حالت GCM هم رمز می‌کند و هم هر دستکاری را تشخیص می‌دهد: اگر یک بیت پیام در راه عوض شود، گیرنده آن را رد می‌کند. کلید ۲۵۶ بیتی در برابر کامپیوتر کوانتومی هم امن می‌ماند.
HKDF-SHA256 RFC 5869	ساخت کلید	ساختن کلید جلسه از رازهای مشترک؛ ساختن کلید و nonce هر پیام	روش استاندارد برای اینکه از چند راز، کلیدهای جدا و مستقل برای کارهای مختلف ساخته شود.
HMAC-SHA256	ساخت کلید زنجیره‌ای	زنجیرهٔ کلید (ratchet): کلید جدا برای هر پیام	کلید هر پیام از کلید قبلی ساخته می‌شود و راه برگشت ندارد. اگر کلید امروز لو برود، پیام‌های دیروز باز نمی‌شوند.
SHA-256	هش	شناسهٔ کلیدها، شناسهٔ مرجع، کد کنترل متن پوششی	استانداردترین تابع هش.

Argon2id RFC 9106	تبدیل رمز به کلید	باز کردن فایل کلید و فایل مرجع با رمزشان؛ ساختن کلید گروه از عبارت عبور	رمزی که آدم‌ها انتخاب می‌کنند کوتاه است. Argon2id هر حدس را عمداً کند و پرهزینه می‌کند (۶۴ مگابایت حافظه و ۳ دور). پس حدس زدن میلیون‌ها رمز با کارت گرافیک عملاً ممکن نیست. برندهٔ مسابقهٔ جهانی رمزهای عبور (۲۰۱۵).
PBKDF2-HMAC-SHA256	تبدیل رمز به کلید	کلید بخش امن از رمز ۶ رقمی برنامه	۲۱۰٬۰۰۰ دور، مطابق توصیهٔ OWASP. جلوی حدس زدن را بیشتر کلید سخت‌افزاری Keystore و محدودیت تعداد تلاش می‌گیرند. PBKDF2 فقط هر حدس روی خود گوشی را گران می‌کند.
BLAKE3	هش	کد دستگاه و کد فعال‌سازی	سازگاری با برنامهٔ ویندوزی موجود منتور (بخش ۳).
SQLCipher	پایگاه‌دادهٔ رمزشده	همهٔ محتوای بخش امن	نسخهٔ رمزشدهٔ SQLite با AES-256. پایگاه‌داده روی دیسک همیشه رمز است، نه فقط هنگام ذخیره.
Android Keystore (TEE / StrongBox)	نگهداری سخت‌افزاری کلید	لایهٔ دوم قفل بخش امن؛ کلید برچسب‌های دفترچهٔ مخفی	کلیدی که داخل تراشهٔ امن گوشی ساخته می‌شود هرگز بیرون نمی‌آید. حتی با کپی کامل حافظهٔ گوشی هم نمی‌شود آن را برداشت.

۶. مسیر یک پیام رمز از نوشتن تا خوانده شدن

فرض کنید علی (گوشی اول) می‌خواهد به رضا (گوشی دوم) پیام رمز بفرستد و هر دو کلیدشان را از بانک کلید سازمان گرفته‌اند.

۶-۱. کلید هر نفر

هر عضو یک جفت‌کلید بلندمدت دارد که در «فایل کلید» به دستش رسیده است (بخش ۹):

- **کلید عمومی** (۱۲۱۷ بایت): ترکیب کلید عمومی ML-KEM-768 (۱۱۸۴ بایت) و X25519 (۳۲ بایت). کلید عمومی همهٔ اعضا در دفترچهٔ امضاشدهٔ سازمان هست.
- **کلید خصوصی** (۹۷ بایت): فقط روی گوشی خود عضو و داخل بخش امن نگه‌داری می‌شود.
- **شناسهٔ کلید** (۸ بایت): ۸ بایت اول هش SHA-256 کلید عمومی. بسته‌ها فرستنده و گیرنده را با همین شناسه مشخص می‌کنند، نه با شمارهٔ تلفن. به همین دلیل اگر کسی از سیم‌کارت دومش جواب بدهد، باز هم درست شناخته می‌شود.
- **گواهی عضو** (۱۰۳ بایت، از ۱۴۰۵/۰۷/۲۵): امضای مرجع روی «شمارهٔ همراه || نسل || کلید X25519» همین عضو (بخش ۹-۷). گوشی آن را در کانال امن برای طرف مقابل می‌فرستد. پس طرف مقابل لازم نیست از پیش کلید او را در دفترچه داشته باشد.

۶-۲. کانال امن: یک بار برای هر دو نفر

بار اولی که علی برای رضا پیام می‌نویسد، برنامه پیش از آن یک «کانال امن» می‌سازد. این کار خودکار است و کاربر فقط پیام «در حال برقراری کانال امن» را می‌بیند. از ۱۴۰۵/۰۷/۲۵ کانال با **گواهی عضو** ساخته می‌شود: علی لازم نیست از پیش کلید رضا را داشته باشد. کافی است شمارهٔ همراه رضا را بداند و فایل هر دو را یک مرجع صادر کرده باشد. این همان چیزی است که اجازه می‌دهد عضو تازه بدون رساندن فایل به بقیه وصل شود.

۱. درخواست از علی (۲ تکه)
گوشی علی یک کلید موقت X25519 می‌سازد و آن را همراه گواهی خودش می‌فرستد: ۱۳۸ بایت، یعنی ۲ تکه پیامک. درخواست نام گیرنده را ندارد؛ هر کس صاحب آن شماره باشد جواب می‌دهد و گواهی‌اش بررسی می‌شود.

۲. پاسخ خودکار رضا (۲ تکه)
گوشی رضا اول امضای مرجع روی گواهی علی را بررسی می‌کند و بعد، بدون دخالت او، با کلید موقت و گواهی خودش و یک کد تأیید جواب می‌دهد: ۱۵۴ بایت، ۲ تکه. رضا هیچ اعلانی برای این بسته نمی‌بیند. علی هم گواهی رضا را بررسی می‌کند. اگر رضا در دفترچهٔ علی بود، کلید گواهی باید همان کلیدی باشد که دفترچه برای او نوشته است.

۳. کلید مشترک
هر دو گوشی از ۳ ترکیب X25519 (موقت با موقت، موقت علی با کلید رضا، کلید علی با موقت رضا) و کل گفتگوی دو بسته با HKDF کلید جلسه را می‌سازند (الگوی Noise XX). هویت هر دو طرف بدون امضای جداگانه تأیید می‌شود و کلیدهای موقت محرمانگی پیشرو می‌دهند. این مرحله هنوز پساکوانتومی **نیست**.

۴. ارسال پیام
پیامی که در صف بود فرستاده می‌شود. در آزمون ۱۴۰۵/۰۷/۲۵ روی دو گوشی واقعی (سامسونگ و هواوی) پیام **حدود ۷ ثانیه** بعد از «ارسال» رفت. پیش‌تر کانال ۲۱ تکه بود و ۵۰ ثانیه طول کشید. از آن به بعد هر پیام فقط یک پیامک است.

۵. ارتقای پساکوانتومی در پس‌زمینه (۲۲ تکه)
پشت پیام‌های کاربر، گوشی علی کلید عمومی ML-KEM-768 خودش را روی همین کانال می‌فرستد (۱۱ تکه). گوشی رضا با آن یک راز تازه می‌سازد و جواب می‌دهد (۱۰ تکه). هر دو از «راز کانال || راز ML-KEM» یک جلسهٔ تازه می‌سازند و علی با یک بستهٔ ۱ تکه‌ای تأیید می‌کند. جلسهٔ تازه امن است اگر **هر کدام** از دو روش امن باشد. در آزمون، ارتقا حدود ۲۵ ثانیه بعد از پیام اول کامل شد. عنوان گفتگو تا آن لحظه «رمزشده · در حال ارتقای پساکوانتومی» است و بعد «رمزشده پساکوانتومی».

- رضا جلسهٔ ارتقایافته را تا وقتی از علی رویش پیامی نشنیده، فقط برای خواندن نگه می‌دارد. اگر جواب او در راه گم شود، دو طرف روی جلسهٔ قبلی می‌مانند و علی بعد از ۳۰ دقیقه، با پیام بعدی، پیشنهاد را تکرار می‌کند.

- اگر هر دو نفر هم‌زمان کانال بسازند، درخواست با شناسهٔ کلید کوچک‌تر برنده می‌شود. درخواست بی‌پاسخ پس از ۱۵ دقیقه، با پیام بعدی یا باز شدن گفتگو، دوباره فرستاده می‌شود.
- **کانال کامل قدیمی** (با ML-KEM و X25519 از همان اول، ۱۰ + ۱۱ تکه) فقط برای فایل‌های بدون گواهی بود. چون برنامه هنوز منتشر نشده و همهٔ اعضا از اول فایل با گواهی (پنل ۱٫۲) می‌گیرند، در عمل به کار نمی‌رود.

۶-۳. کلید جدا برای هر پیام

کلید جلسه مستقیم برای رمز کردن پیام به کار نمی‌رود. برای هر جهت (علی به رضا و رضا به علی) یک زنجیرهٔ کلید ساخته می‌شود. هر پیام کلید خودش را از حلقهٔ فعلی زنجیره می‌گیرد و زنجیره یک قدم جلو می‌رود (با HMAC-SHA256). از حلقهٔ جدید نمی‌توان به حلقه‌های قبلی رسید. پس:

- هیچ دو پیامی با یک کلید رمز نمی‌شوند.
- کلیدها برای هر مخاطب هم جدا هستند و هر جفت آدم زنجیرهٔ خودش را دارد.
- پیامکی که دیرتر یا جابه‌جا برسد (تا ۱۰۰۰ پیام جلوتر) درست خوانده می‌شود. پیامکی که اپراتور دو بار تحویل دهد یک بار ثبت می‌شود و پیامک دستکاری‌شده رد می‌شود.
- وضعیت زنجیره همیشه **پیش از** ارسال پیامک ذخیره می‌شود. حتی اگر برنامه وسط کار بسته شود، هیچ کلیدی دو بار مصرف نمی‌شود.

۶-۴. شکل بستهٔ پیام

بخش	محتوا
بیرون بسته (آشکار)	یک بایت نسخه و نوع بسته؛ شناسهٔ جلسه (۲ بایت)؛ شمارهٔ پیام. این‌ها رمز نیستند، اما در برابر دستکاری محافظت می‌شوند.
داخل بسته (رمزشده)	نوع محتوا، پرچم‌ها (حذف پس از دیدن، پیام گروهی، پیام زمان‌دار)، شناسهٔ گروه و مدت زمان‌دار در صورت وجود، و خود متن.
انتهای بسته	برچسب ۱۶ بایتی GCM که هر دستکاری را آشکار می‌کند.
متن فارسی	برای اینکه پیام فارسی در یک پیامک جا شود، یک جدول کد فشرده دارد که هر حرف فارسی را ۱ بایت می‌کند (در UTF-8 هر حرف ۲ بایت است). نتیجه: **یک پیامک رمز تا حدود ۹۶ حرف فارسی** جا می‌گیرد. پیامک فارسی عادی ۷۰ حرف جا دارد.

بستهٔ نهایی با Base64 به حروف و ارقام لاتین تبدیل می‌شود و `#E:` جلویش می‌آید. چون فقط حروف لاتین دارد، هر پیامک ۱۶۰ نویسه جا دارد.

این قالب با «بردار طلایی» قفل شده است: یک پیام نمونهٔ ثابت در آزمون‌ها که اگر کسی قالب را ناخواسته عوض کند، آزمون شکست می‌خورد. هر تغییر عمدی در قالب، شمارهٔ نسخهٔ پروتکل را بالا می‌برد. پس پیام‌های قدیمی همیشه خوانا می‌مانند.

۶-۵. در گوشی گیرنده

- اگر بخش امن قفل باشد، برنامه متن رمزشده را (نه متن اصلی) همراه شمارهٔ فرستنده و زمان در یک صف موقت می‌گذارد و فقط اعلان «پیام رمز جدید» نشان می‌دهد، بدون نام فرستنده و بدون متن.
- بسته‌های کنترلی (کانال امن، «دیده شد»، مشخصات گروه) اعلانی نمی‌سازند.
- با باز شدن بخش امن، صف خوانده و پیام‌ها رمزگشایی می‌شوند. بسته‌ای که هنوز قابل خواندن نیست، مثلاً پیامی که زودتر از پاسخ کانال امن رسیده، تا ۷ روز نگه داشته می‌شود.

- اگر رضا گفتگو را باز کند، برنامه خودکار یک رسید «دیده شد» برای علی می‌فرستد. این رسید هم رمز است و یک پیامک هزینه دارد. ارسالش از منوی «پیام‌های رمز» قابل خاموش کردن است.

آنچه فراهم نیست: اگر روزی کلیدهای بلندمدت **هر دو** طرف هم‌زمان دزدیده شوند و کامپیوتر کوانتومی هم در کار باشد، پیام‌های ضبط‌شدهٔ قبلی در خطرند. محافظت در برابر این حالت (post-quantum forward secrecy) حدود ۲٫۳ کیلوبایت، یعنی نزدیک ۲۰ قطعه پیامک، به هر کانال امن اضافه می‌کند. محافظت کلاسیکِ همین حالت با کلیدهای موقت X25519 فراهم است.

از ۱۴۰۵/۰۷/۲۵: پیام‌هایی که در کانال گواهی **پیش از تمام شدن ارتقا** رفته‌اند (معمولاً پیام اول، و هر پیامی در همان چند ده ثانیه) فقط با X25519 محافظت می‌شوند. مهاجمی که آن چند پیامک را امروز ضبط کند و روزی کامپیوتر کوانتومی داشته باشد، می‌تواند همان‌ها را باز کند. این هزینهٔ آگاهانهٔ «اولین تماس با ۴ تکه» است. برای پیامی که حتی این خطر را ندارد، کاربر می‌تواند پیش از نوشتن آن صبر کند تا عنوان گفتگو «رمزشده پساکوانتومی» شود.

۷. اپراتور و برنامه‌های دیگر چه می‌بینند

پیام رمز هم‌رسان یک پیامک معمولی است و از همان مسیر همیشگی اپراتور می‌گذرد. پس سؤال طبیعی این است که در این مسیر، دقیقاً چه چیزی دیده می‌شود.

۷-۱. اپراتور

اپراتور (و هر کسی که به سامانهٔ پیامک اپراتور یا مسیر رادیویی دسترسی داشته باشد) متنی شبیه این می‌بیند:

```
#E:EfVPANLwWegqLwhcwj75xMvt8l5JnJiYUp8epCJHFPyV5yxLMEeqNJDocOf9xtSk
```

این یک پیامک واقعی هم‌رسان است (همان «بردار طلایی» آزمون‌ها). بله، اپراتور یک رشتهٔ بی‌معنی از حروف و ارقام لاتین می‌بیند. هیچ کلمه‌ای از متن اصلی، هیچ اشاره‌ای به اینکه پیام فارسی بوده، و هیچ نشانه‌ای از نوع پیام (عادی، زمان‌دار، گروهی یا «حذف پس از دیدن») در آن نیست. همهٔ این‌ها داخل بخش رمزشده‌اند.

اپراتور نمی‌تواند	اپراتور می‌تواند
• متن پیام را بخواند، حتی اگر همهٔ پیامک‌ها را سال‌ها نگه دارد • پیام را بدون اینکه گیرنده بفهمد تغییر دهد (پیام دستکاری‌شده رد می‌شود) • پیام جعلی به نام یکی از اعضا بسازد • بفهمد کدام پیام زمان‌دار، گروهی یا «حذف پس از دیدن» بوده	• ببیند چه شماره‌ای به چه شماره‌ای، کی و چند پیامک فرستاده (این اطلاعات جزو خود سامانهٔ پیامک است و هیچ برنامه‌ای نمی‌تواند پنهانش کند) • از شکل `#E:` بفهمد که این پیامک یک پیام رمز است (در نسخهٔ سازمانی، «متن پوششی» همین را هم پنهان می‌کند) • پیامک را دیر برساند یا نرساند. در آزمون ما یک پیامک ۱۷ دقیقه در شبکه ماند و بعد رسید. برنامه آن را درست و سر جای خودش نشان داد.

۷-۲. برنامه‌های دیگر گوشی (مثل Google Messages)

- **اگر هم‌رسان برنامهٔ پیش‌فرض پیامک باشد** (که برنامه موقع نصب درخواستش می‌کند): پیام رمز اصلاً در حافظهٔ پیامک اندروید (content://sms) نوشته نمی‌شود، نه موقع ارسال و نه موقع دریافت. پس برنامه‌های دیگر، از جمله Google Messages، پشتیبان‌گیری گوگل و برنامه‌هایی که اجازهٔ خواندن پیامک دارند، **هیچ اثری از آن نمی‌بینند**.
- **اگر هم‌رسان پیش‌فرض نباشد:** اندروید خودش پیامک دریافتی را در حافظهٔ پیامک ذخیره می‌کند. هم‌رسان باز هم آن را می‌گیرد و رمزگشایی می‌کند، اما برنامهٔ پیامک دیگر همان رشتهٔ `#E:EfVP…` را به شکل یک پیامک عجیب نشان می‌دهد. متن اصلی آنجا هم دیده نمی‌شود، ولی اینکه پیام رمزی آمده آشکار است. صفحهٔ «کنترل امنیت سامانه» در این حالت هشدار می‌دهد.
- **اعلان‌ها:** اعلان پیام رمز فقط می‌گوید «پیام رمز جدید · برای خواندن، بخش امن را باز کنید». نام فرستنده و متن در اعلان نیست. پس روی صفحهٔ قفل گوشی، ساعت هوشمند یا برنامه‌هایی که اعلان‌ها را می‌خوانند هم چیزی لو نمی‌رود.

۷-۳. متن پوششی (فقط نسخهٔ سازمانی)

در نسخهٔ سازمانی می‌توان پیام رمز را به جای `#E:…` به شکل یک متن معمولی فرستاد. هر بایت بستهٔ رمزشده با یکی از ۲۵۶ کلمهٔ یک فهرست ثابت جایگزین می‌شود. ۲ کلمهٔ کنترلی هم در آخر می‌آید و بعد از هر ۹ کلمه یک نقطه گذاشته می‌شود. همان پیام نمونهٔ بالا در دو حالت متن پوششی این شکلی است:

معلم صدف تخت خانه کمی کشید قهوه خندید کارگر. تلفن دریا نمک آنجا برف قایق پایین نیمه افتاد. پخت گوشت چوب مسابقه بازی بازی در دکتر قطار. قلب بازار صحرا مادر شمع شعر پرید جلسه طلا. ساعت صحرا دهان ظهر کاغذ خندید کاسه پرید کلید. عقب شاید قلب کلید کار.

```
problem sugar level time river cat change sun right. word life research baby member milk type window hors
e. apple guy body event paper paper health center night. star room idea place glass position cloud book b
ack. business idea cost head model sun experience cloud plate. film winter star plate story.
```

- این متن معنای جمله‌ای ندارد، اما برخلاف `#E:…` در نگاه اول و برای فیلترهای خودکار شبیه یک پیامک عادی است. هدفش این است که پیام رمز در میان پیامک‌های دیگر به چشم نیاید.
- گیرنده به کلید جداگانه‌ای نیاز ندارد. برنامه خودش تشخیص می‌دهد که همهٔ کلمه‌ها از فهرست‌اند و کد کنترلی درست است، متن را به بستهٔ اصلی برمی‌گرداند و بعد رمزگشایی می‌کند. امنیت پیام همان امنیت `#E:` است. متن پوششی چیزی به رمز اضافه نمی‌کند، فقط شکل ظاهری را عوض می‌کند.
- **هزینه:** هر بایت یک کلمه می‌شود. یک پیام کوتاه فارسی به‌جای ۱ پیامک، ۲ تا ۴ پیامک می‌شود. برای همین فقط برای پیام‌ها و رسیدها به کار می‌رود، نه برای ساختن کانال امن.
- از منوی «پیام‌های رمز» روشن می‌شود: «متن پوششی: فارسی» یا «متن پوششی: انگلیسی».

۸. بخش امن

«بخش امن» قسمتی از برنامه است که همهٔ محتوای محرمانه داخلش نگه داشته می‌شود: پیام‌های رمز، گروه‌ها، کلیدها، دفترچهٔ مخفی، تماس‌های مخفی و عکس‌های ورود ناموفق. بیرون از آن، برنامه مثل یک پیام‌رسان معمولی است.

- **آیکون قفل:** بالای همهٔ زبانه‌ها یک آیکون قفل هست (فقط در نسخه‌های امن). قفل بسته یعنی هیچ نشانه‌ای از محتوای امن روی صفحه نیست، حتی ردیف‌های «پیام‌های رمز» و «دفترچه مخفی». با لمس قفل و وارد کردن رمز، این ردیف‌ها ظاهر می‌شوند.
- **رمز:** بخش امن با همان رمز ورود برنامه باز می‌شود که در نسخه‌های امن **۶ رقمی** است. بعد از ۵ تلاش اشتباه، برنامه ۳۰ ثانیه صبر می‌کند و هر بار این زمان دو برابر می‌شود تا ۳۰ دقیقه.
- **نحوهٔ قفل:** محتوا در یک پایگاه‌دادهٔ جدای رمزشده (SQLCipher) است. کلیدش ۳۲ بایت تصادفی است که دو بار قفل شده: یک بار با کلیدی که از رمز ۶ رقمی ساخته می‌شود (PBKDF2، ۲۱۰٬۰۰۰ دور، سپس AES-256-GCM) و یک بار با کلید سخت‌افزاری Android Keystore که از تراشهٔ امن گوشی بیرون نمی‌آید. پس کپی فایل‌ها روی دستگاه دیگر به هیچ دردی نمی‌خورد، چون حدس زدن رمز فقط روی خود گوشی ممکن است و آنجا هم محدودیت تعداد تلاش دارد.
- **قاعدهٔ اصلی:** هیچ چیز محرمانه‌ای در پایگاه‌دادهٔ اصلی برنامه، حافظهٔ پیامک اندروید یا سوابق تماس اندروید نوشته نمی‌شود.
- **قفل خودکار:** با خروج از برنامه، بخش امن فوراً بسته می‌شود. اگر کاربر داخل یک گفتگو بوده باشد، بعد از وارد کردن رمز همان گفتگو با پیام‌هایش دوباره نشان داده می‌شود. (قفل خود برنامه جداست و بعد از مدت «قفل خودکار» تنظیمات بسته می‌شود؛ بخش ۱۳.)
- **جلوگیری از اسکرین‌شات:** وقتی بخش امن باز است، اسکرین‌شات و فیلم‌برداری از صفحه سیاه درمی‌آید و تصویر برنامه در فهرست برنامه‌های اخیر خالی است (FLAG_SECURE). متن پیام‌های رمز قابل انتخاب و کپی نیست و صفحه‌کلید اجازهٔ یادگیری کلمات آن را ندارد.
- **فراموشی رمز:** با کد بازیابی می‌توان دوباره وارد برنامه شد، اما **محتوای بخش امن از بین می‌رود**. هر راه بازیابی محتوا در عمل یک در پشتی است که دیگران هم می‌توانند از آن استفاده کنند.

۹. بانک کلید و فایل کلید

برای اینکه دو نفر بتوانند پیام رمز رد و بدل کنند، هر کدام باید کلید عمومی دیگری را داشته باشد و مطمئن باشد که آن کلید واقعاً مال همان شخص است. «بانک کلید» جایی در برنامه است که این کلیدها نگه داشته می‌شوند. مسیرش این است: تنظیمات ← امنیت ← «بانک کلید» (وقتی بخش امن باز است).

۹-۱. اصطلاحات

اصطلاح	یعنی چه و کجا به کار می‌رود
مرجع کلید (authority)	شخص یا واحدی در سازمان که کلید اعضا را صادر می‌کند. مرجع با یک ابزار ویندوزی کار می‌کند و یک «کلید امضا» دارد که فقط نزد خودش است. نقشش شبیه دفتر صدور کارت شناسایی است.
کلید عمومی مرجع	نیمهٔ عمومی کلید امضای مرجع (۱۹۸۵ بایت: ML-DSA-65 و Ed25519). **داخل خود برنامه** قرار گرفته است. برنامه با آن امضای مرجع را بررسی می‌کند. محرمانه نیست، چون با آن فقط می‌شود امضا را بررسی کرد، نه ساخت. کلید فعلی برنامه شناسهٔ `b45a8048bd2d0314` دارد.
دفترچهٔ سازمان (directory)	فهرست امضاشدهٔ اعضای یک سازمان: نام سازمان و برای هر عضو نام، حداکثر ۸ شماره و کلید عمومی‌اش. این همان «بانک کلید عمومی» سازمان است. همه یک نسخه از آن دارند و چون امضاشده است، کسی نمی‌تواند در آن کلید جعلی جا بزند.
فایل کلید (`.hkb`)	فایلی که مرجع برای هر عضو جداگانه می‌سازد. دو چیز دارد: دفترچهٔ امضاشدهٔ سازمان، و کلید خصوصی همان عضو. با یک رمز ۲۰ نویسه‌ای قفل است.
رمز فایل کلید	۲۰ نویسه از حروف بزرگ لاتین و ارقام، مثل `K7QM-2XRA-…` . هنگام وارد کردن، حروف کوچک، فاصله و خط تیره اهمیتی ندارند. رمز باید از راهی جدا از خود فایل به عضو برسد.
گروه عبارت عبور	راه دوم و ساده‌تر برای ساختن کلید، بدون مرجع و فایل. اعضا یک نام گروه و یک جملهٔ رمز مشترک (حداقل ۱۲ نویسه) وارد می‌کنند و برنامه از آن برای هر شماره کلید جدا می‌سازد (بخش ۹-۶).
شماره‌های من	شمارهٔ سیم‌کارت‌های همین گوشی. فقط برای گروه‌های عبارت عبور لازم است، چون آنجا کلید هر عضو از شماره‌اش ساخته می‌شود.
نسل (generation)	عددی کنار هر عضو در فهرست مرجع (۰ تا ۲۵۵). با گم شدن گوشی یک عضو، نسلش یکی زیاد می‌شود تا کلید تازه بگیرد و کلید قبلی از دفترچه حذف شود. نسل داخل گواهی هم هست و گوشی گواهی با نسل کمتر از آنچه دیده را نمی‌پذیرد.
گواهی عضو	امضای مرجع روی شمارهٔ همراه، نسل و کلید X25519 یک عضو؛ داخل فایل کلید خود او. با آن عضو بدون اینکه در دفترچهٔ طرف مقابل باشد شناخته می‌شود (بخش ۹-۷).

۹-۲. ساختار دقیق فایل کلید (`.hkb`)

فایل کلید دو لایه دارد: یک سرآیند آشکار و یک بدنهٔ رمزشده.

بخش	اندازه	توضیح
نشانه	۵ بایت	متن `HMRKB` . برنامه از آن می‌فهمد این فایل کلید هم‌رسان است.
نسخهٔ قالب	۱ بایت	فعلاً `1`

هزینهٔ Argon2id	۶ بایت	تعداد دور (۳)، حافظه (۶۵۵۳۶ کیلوبایت = ۶۴ مگابایت) و موازی‌سازی (۱). برنامه پیش از شروع بررسی می‌کند که این اعداد از سقف مجاز بیشتر نباشد، تا یک فایل مخرب نتواند گوشی را از کار بیندازد.
نمک (salt)	۱۶ بایت	عدد تصادفی که باعث می‌شود رمز یکسان در دو فایل، کلید یکسان نسازد.
nonce	۱۲ بایت	عدد تصادفی AES-GCM
بدنهٔ رمزشده	بقیهٔ فایل	با AES-256-GCM و کلیدی که Argon2id از رمز فایل می‌سازد رمز شده است. سرآیند هم جزو داده‌های محافظت‌شده است و اگر یک بایتش عوض شود، فایل باز نمی‌شود.
داخل بدنه: قالب بدنه	۱ بایت	`2` از پنل ۱٫۲ (۱۴۰۵/۰۷/۲۵)، با گواهی. قالب `1` قبلی، بدون گواهی، هنوز باز می‌شود.
داخل بدنه: دفترچهٔ امضاشده	چند کیلوبایت	نسخهٔ قالب، شناسهٔ مرجع (۸ بایت)، شناسهٔ دفترچه (۸ بایت)، شمارهٔ ترتیب (زمان صدور به میلی‌ثانیه)، نام سازمان، و برای هر عضو نام و شماره‌ها و کلید عمومی ۱۲۱۷ بایتی. سپس امضای ترکیبی: `1 ‖ Ed25519 (64 B) ‖ ML-DSA-65 (3309 B)`
داخل بدنه: کلید عضو	۱۰۰ بایت	شمارهٔ ردیف عضو در دفترچه و کلید خصوصی ۹۷ بایتی او. برنامه فقط وقتی کلید را می‌پذیرد که نیمهٔ عمومی‌اش دقیقاً همان کلیدی باشد که دفترچهٔ امضاشده برای این عضو نوشته است.
داخل بدنه: گواهی عضو	۱۰۳ بایت	فقط در قالب ۲ (بخش ۹-۷). برنامه هنگام وارد کردن بررسی می‌کند که امضای گواهی از همان مرجع باشد، کلید خود همین فایل را گواهی کند و شمارهٔ گواهی یکی از شماره‌های همین عضو باشد.

اندازهٔ فایل یک سازمان دونفره حدود ۶ کیلوبایت است و با هر عضو حدود ۱٫۳ کیلوبایت بیشتر می‌شود. نام فایل اهمیتی ندارد. ابزار مرجع آن را به شکل `شماره-NNN.hkb` می‌سازد، مثل `002-09356455230.hkb` .

۹-۲-۱. فایل به‌روزرسانی (`update.hku`)

با هر صدور، کنار فایل اعضا یک فایل به‌روزرسانی هم ساخته می‌شود: **همان دفترچهٔ امضاشده، بدون کلید خصوصی هیچ‌کس**. برای همه یکی است و رمز نمی‌خواهد، پس مرجع می‌تواند بعد از هر تغییر فهرست، یک فایل را برای همهٔ اعضا بفرستد. **از ۱۴۰۵/۰۷/۲۵ برای پیام رمز لازم نیست:** عضو تازه با گواهی‌اش شناخته می‌شود. این فایل فقط نام اعضای تازه را به فهرست «گفتگوی رمز» می‌آورد. گواهی هم ندارد و جای فایل خود عضو را نمی‌گیرد.

ویژگی	چطور
نشانه	`HMRKU` . برنامه از همین سرآیند آشکار می‌فهمد که فایل به‌روزرسانی است و پنجرهٔ رمز را نشان نمی‌دهد.
قفل	همان ساختار فایل کلید (Argon2id و AES-256-GCM)، ولی «رمزش» از **شناسهٔ ۶۴ بیتی دفترچه** ساخته می‌شود. این شناسه را فقط گوشی‌ای دارد که قبلاً فایل کلید همین سازمان را وارد کرده. پس عضو بدون رمز بازش می‌کند و غریبه نمی‌تواند فهرست اعضا را بخواند. عضو سابق شناسه را دارد، ولی فهرست را از قبل هم می‌دانست.
اصالت	از قفل نمی‌آید. دفترچهٔ داخلش مثل فایل کلید با هر دو امضای مرجع بررسی می‌شود.

هم‌خوانی با فایل کلید	از **همان** دفترچهٔ امضاشدهٔ فایل‌های همان صدور ساخته می‌شود (همان شمارهٔ ترتیب). پس وارد کردن هر دو، به هر ترتیبی، هیچ‌وقت به «فایل قدیمی‌تر است» نمی‌خورد.
کلید تازهٔ خود عضو	در آن نیست. اگر کلید عضوی عوض شده باشد و او به‌جای فایل خودش فایل به‌روزرسانی را وارد کند، برنامه می‌گوید «کلید شما در آن عوض شده است» و فایل خودش را می‌خواهد.

۹-۳. شرایط پذیرفته شدن فایل کلید

۱. فایل باید روی گوشی باشد، هر جا: دانلودها، فلش، کارت حافظه یا فایلی که از پیام‌رسان ذخیره شده. برنامه با پنجرهٔ انتخاب فایل خود اندروید آن را می‌گیرد و به هیچ مجوز اضافه‌ای نیاز ندارد.

۲. رمز ۲۰ نویسه‌ای باید درست باشد. رمز اشتباه با پیام «رمز فایل کلید اشتباه است» رد می‌شود و هیچ چیزی تغییر نمی‌کند.

۳. امضای دفترچه باید با کلید عمومی مرجعی که داخل برنامه است بخواند و **هر دو** امضا باید معتبر باشند. در غیر این صورت: «این فایل را مرجعی امضا کرده که این برنامه به آن اعتماد ندارد» یا «امضای فایل معتبر نیست؛ فایل دستکاری شده است».

۴. اگر دفترچه‌ای از همان سازمان قبلاً وارد شده باشد: فایل **جدیدتر** جایگزین می‌شود، فایل **قدیمی‌تر** رد می‌شود و فایل تکراری پیام «این فایل قبلاً وارد شده است» می‌گیرد.

۵. اگر در دفترچهٔ جدید کلید این عضو دیگر نباشد (مثلاً نسلش عوض شده)، کلید قبلی کنار گذاشته می‌شود.

۶. **گفتگوهای موجود دنبال دفترچه می‌روند.** اگر کلید یک همکار در دفترچهٔ تازه عوض شده باشد (گوشی‌اش گم شده)، گفتگوی رمز با او خودش به کلید تازه منتقل می‌شود: نشست‌های قبلی کنار گذاشته می‌شوند و پیام بعدی با کلید تازه کانال می‌سازد. پیامی که روی نشست کلید کنارگذاشته برسد خوانده نمی‌شود. (پیش از ۱۴۰۵/۰۷/۱۵ گفتگو تا ابد با کلید اول می‌ماند و گوشی گم‌شده همچنان پیام‌ها را می‌خواند.) **از ۱۴۰۵/۰۷/۲۵ با گواهی عضو:** گفتگو با یک عضو، اگر دفترچه دیگر کلیدی برای او نداشته باشد، از راه گواهی ادامه پیدا می‌کند؛ یعنی **حذف از دفترچه دیگر جلوی پیام عضو حذف‌شده را نمی‌گیرد** (ابطال وجود ندارد؛ بخش ۱۷). کلید تازهٔ عضوی که گوشی‌اش گم شده هم بدون فایل به‌روزرسانی، با اولین گواهی تازه‌اش جایگزین می‌شود.

وارد کردن یک فایل روی گوشی آزمون بین نیم تا یک‌ونیم ثانیه طول کشید. بعد از آن در بانک کلید نام سازمان، تعداد اعضا، تاریخ صدور و «کلید شما: ...» نمایش داده می‌شود و همهٔ اعضای دفترچه در فهرست «گفتگوی رمز» دیده می‌شوند. به عضوی که در دفترچه نیست، با نوشتن شمارهٔ همراه کاملش پیام داده می‌شود.

۹-۴. صدور کلید با ابزار مرجع

روش اصلی، برنامهٔ پنجره‌ای «پنل صدور همرسان» (نسخهٔ ۱٫۲، فایل نصب `HamresanPanel-1.2.0.msi`) است که راهنمای جداگانه دارد. نسخهٔ ۱٫۲ در هر فایل کلید گواهی عضو می‌گذارد. اولین بار که پوشهٔ مرجعی از پیش از ۱٫۲ را باز می‌کند، فایل همهٔ اعضا را با همان کلید و رمز ولی با گواهی دوباره می‌سازد (زمانش در `certificates.txt`) و کنار هر عضوی که فایل تازه‌اش را نگرفته «فایل بدون گواهی» می‌نویسد. پنل علاوه بر کد فعال‌سازی و افزودن عضو، این کارها را هم انجام می‌دهد: نشان می‌دهد چه کسی فایل قدیمی دارد (از روی «دفتر صدور»، فایل `issuance-log.csv`)، دکمهٔ «گوشی گم شد» (کلید **و رمز** تازه؛ کلیدی که یک بار کنار گذاشته شد هرگز دوباره ساخته نمی‌شود)، ویرایش و حذف عضو، و فایل به‌روزرسانی. صدور «همه یا هیچ» است: اگر وسط کار خطا پیش بیاید، هیچ فایلی عوض نمی‌شود.

ابزار خط فرمان هم هنوز هست. این ابزار یک برنامهٔ خط فرمان ویندوزی است (`hamresan-keybank.jar` به‌همراه `hamresan-keybank.cmd`) که به جاوا نسخهٔ ۱۱ یا بالاتر نیاز دارد. این ابزار از همان کد رمزنگاری خود برنامه ساخته شده است، پس هر فایلی که بسازد، برنامه دقیقاً همان را می‌خواند.

#	دستور	کار
۱	`hamresan-keybank init authority.hka`	ساختن مرجع، فقط یک بار. یک رمز دست‌کم ۱۲ نویسه‌ای می‌خواهد.

۲	`hamresan-keybank public authority.hka`	چاپ کلید عمومی مرجع به شکل یک خط هگز طولانی (۳۹۷۰ نویسه). این خط داخل برنامه قرار می‌گیرد.
۳	`roster.csv`	فهرست اعضا. در اکسل با قالب «CSV UTF-8» ذخیره می‌شود (نمونه در ادامه).
۴	`hamresan-keybank issue authority.hka roster.csv out`	برای هر عضو فایل `out\NNN-شماره.hkb` ، برای همه یک `out\passwords.csv` و یک فایل به‌روزرسانی `out\update.hku` می‌سازد.
۵	`hamresan-keybank inspect out\001-….hkb authority-public.txt`	بررسی یک فایل، اختیاری

```
organization,سازمان نمونه همرسان
name,phones,generation
09034853204,علی رودی
09356455230,گوشی دوم
```

- چند شماره برای یک عضو با `;` جدا می‌شوند. شماره در هر شکلی پذیرفته می‌شود (`+98…` ، `0912…` ، ارقام فارسی).
- کلید هر عضو از **اولین شماره‌اش** و نسلش ساخته می‌شود: `HKDF(seed ‖ نسل ‖ شماره عضا)` . پس ترتیب شماره‌ها نباید عوض شود. پیامک رمز هم به اولین شمارهٔ همراه عضو فرستاده می‌شود.
- **عضو جدید:** به فهرست اضافه و دوباره صادر می‌شود. کلید و رمز اعضای قبلی عوض نمی‌شود. **فقط عضو جدید فایل لازم دارد؛** بقیه با شمارهٔ همراه او از راه گواهی به او می‌رسند. فایل به‌روزرسانی اختیاری است و فقط نامش را به فهرست گوشی‌ها می‌آورد.
- **گم شدن گوشی یک عضو:** در پنل «گوشی گم شد» (یا در فهرست، نسل او یکی زیاد و دوباره صادر شود). کلید قدیمی دیگر در دفترچه نیست. هر گوشی‌ای که یک بار گواهی نسل تازهٔ او را ببیند، از آن به بعد گواهی نسل قبلی را نمی‌پذیرد. گوشی‌ای که هنوز آن را ندیده، کلید گوشی گم‌شده را می‌پذیرد (بخش‌های ۹-۳ و ۱۷).
- چون مرجع کلید همهٔ اعضا را از یک seed می‌سازد، **هر زمان می‌تواند کلید هر عضو را بازسازی کند.** این ویژگی صدور دوباره را ساده می‌کند، اما یعنی مرجع در صورت نیاز می‌تواند پیام اعضا را هم بخواند (بخش ۱۷).

۹-۵. مرجع آزمایشی و مرجع واقعی

در دوران توسعه یک مرجع آزمایشی وجود داشت. برنامه فقط وقتی به آن اعتماد می‌کند که با یک تنظیم خاص برای توسعه ساخته شده باشد. در این حالت بانک کلید یک نوار قرمز «نسخه آزمایشی» نشان می‌دهد. اسکریپت ساخت نسخهٔ نهایی هر فایل نصبی‌ای را که کلید آزمایشی داشته باشد رد می‌کند. **مرجع واقعی** برای این پروژه ساخته شده و کلید عمومی‌اش داخل برنامه است (بخش ۱۰). نسخهٔ نهایی فقط فایل‌های همین مرجع را قبول می‌کند.

۹-۶. گروه عبارت عبور

- از نام گروه و عبارت عبور با Argon2id یک seed ساخته می‌شود و کلید هر عضو از این seed و شمارهٔ او. پیش از ساخت، عبارت و نام یکسان‌سازی می‌شوند (حروف بزرگ و کوچک، «ی» و «ک» عربی، ارقام فارسی، فاصله‌ها). پس همهٔ گوشی‌ها به یک نتیجه می‌رسند.
- برنامه یک «کد گروه» ۱۶ نویسه‌ای نشان می‌دهد، مثل `AF15-EC4C-2B89-D00B` . اعضا می‌توانند آن را تلفنی با هم مقایسه کنند تا مطمئن شوند عبارت را یکسان وارد کرده‌اند.
- خود عبارت ذخیره نمی‌شود. فقط seed در بخش امن نگه‌داری می‌شود.

هر کس عبارت عبور را بداند، کلید **همهٔ** اعضای آن گروه را می‌سازد و می‌تواند پیام‌هایشان را بخواند یا به نام هر کدام پیام بفرستد. این روش برای گروه‌های کوچک و مورد اعتماد است. برای سازمان، فایل کلید مرجع روش اصلی و امن‌تر است.

۷-۹. گواهی عضو (از ۱۴۰۵/۰۷/۲۵)

مسئله: تیم محصول و منتور یادآوری کردند که با دفترچه، هر عضو تازه یعنی رساندن فایل تازه به **همهٔ** اعضا پیش از اینکه کسی بتواند به او پیام بدهد؛ و وقتی اینترنت قطع است و فقط پیامک کار می‌کند، این عملاً ممکن نیست. نرم‌افزار قبلی (qksms) این مشکل را نداشت، چون اصلاً کلید جدا برای هر نفر نداشت: یک «بانک» مشترک، دو شمارهٔ تلفن و یک رمز مشترک کلید هر پیام را می‌ساختند. یعنی هر کس بانک را داشت، پیام همه را می‌خواند. راه انتخاب‌شده (گزینهٔ «ب»، به تصمیم مالک پروژه) گواهی است: هر عضو کلید خودش را دارد، ولی مرجع کلید او را **برای شماره‌اش** امضا می‌کند و عضو این امضا را خودش همراه دارد.

بخش گواهی	اندازه	توضیح
قالب	۱ بایت	`1`
شمارهٔ همراه	۵ بایت	۱۰ رقم بعد از صفر، دو رقم در هر بایت. فقط شماره‌های `09…` گواهی می‌گیرند؛ پنل گواهی را برای اولین شمارهٔ همراه عضو می‌سازد.
نسل	۱ بایت	۰ تا ۲۵۵. پنل بیش از ۲۵۵ بار «گوشی گم شد» را برای یک عضو نمی‌پذیرد.
کلید X25519	۳۲ بایت	نیمهٔ کلاسیک کلید عمومی همین عضو، همان که در دفترچه هست.
امضای Ed25519 مرجع	۶۴ بایت	روی همهٔ بخش‌های بالا به‌علاوهٔ شناسهٔ مرجع. شناسهٔ مرجع فرستاده نمی‌شود؛ گیرنده امضا را با هر کلید مرجعی که داخل برنامه است امتحان می‌کند.

- **چرا فقط Ed25519:** امضای ML-DSA-65 ۳۳۰۹ بایت است و هر اولین تماس را به حدود ۳۰ تکه می‌رساند. مالک پروژه خواست اولین تماس چند تکه باشد، حتی به بهای کمی امنیت. معنایش این است: کسی که روزی کامپیوتر کوانتومی داشته باشد، می‌تواند از روی کلید عمومی مرجع گواهی جعلی بسازد. دفترچهٔ سازمان همچنان امضای ترکیبی دارد.
- **شناسهٔ کلید گواهی:** ۸ بایت اول SHA-256 روی یک برچسب ثابت و کلید X25519. برنامهٔ اندروید و بخش فلاتر همین را جداگانه حساب می‌کنند و هر دو با یک بردار آزمون ثابت قفل شده‌اند.
- **بررسی‌ها پیش از هر کار:** گواهی رسیده پیش از اینکه چیزی ذخیره یا جوابی فرستاده شود بررسی می‌شود. گفتگو زیر شماره‌ای ثبت می‌شود که خود گواهی می‌گوید، نه شماره‌ای که پیامک از آن آمده.
- **شمارهٔ تایپ‌شده:** برنامه فقط برای شماره‌ای که کاربر خودش در «گفتگوی رمز» تایپ کرده درخواست گواهی می‌فرستد و پیش از آن هشدار «این شماره در دفترچهٔ کلید نیست» را نشان می‌دهد. مخاطب مخفی‌ای که عضو نیست هیچ‌وقت خودکار درخواست نمی‌گیرد، چون فقط یک پیامک نامفهوم می‌دید.
- **گروه رمز:** عضوی که از راه گواهی در گروه است و هنوز جواب نداده، با شناسهٔ کلید صفر در تعریف گروه می‌آید. گیرنده‌ها خودشان را با شمارهٔ گواهی‌شان می‌شناسند و بقیه را با شماره پیدا می‌کنند.

۱۰. پوشهٔ مرجع کلید: C:\Users\hp\Hamresan-Authority

این پوشه «دفتر مرجع کلید» این پروژه است. به تصمیم مالک پروژه، مرجع واقعی را خودمان ساختیم تا برنامه پیش از جلسه با کلید واقعی آزموده شود. پوشه عمداً **بیرون از مخزن کد** است و هیچ‌وقت در git ثبت نشده است، چون کلید خصوصی مرجع در آن است.

فایل	محرمانه؟	چیست و چه کار می‌کند
`authority.hka`	بسیار محرمانه	**کلید خصوصی مرجع.** با نشانهٔ `HMRKA` شروع می‌شود و ساختارش مثل فایل کلید است: سرآیند Argon2id و بدنهٔ AES-256-GCM که با رمز مرجع قفل شده. داخلش سه عدد تصادفی ۳۲ بایتی است: seed امضای ML-DSA، seed امضای Ed25519 و seed اعضا که کلید همهٔ اعضا از آن ساخته می‌شود. هر کس این فایل و رمزش را داشته باشد، می‌تواند برای کل سازمان کلید صادر کند، عضو جعلی بسازد یا کلید هر عضو را بازسازی کند. اگر گم شود، باید مرجع تازه ساخته شود، برنامه با کلید عمومی جدید منتشر شود و برای همه فایل کلید تازه صادر شود.
`authority-password.txt`	بسیار محرمانه	رمز فایل بالا. فقط برای این دورهٔ آزمون کنار فایل گذاشته شده تا کار متوقف نشود. **در استفادهٔ واقعی، رمز مرجع هرگز نباید روی همان رایانه و کنار فایل نوشته شود.** جای درستش حافظهٔ مسئول مرجع یا یک گاوصندوق است.
`authority-public.txt`	عمومی	کلید عمومی مرجع: یک خط هگز ۳۹۷۰ نویسه‌ای (۱۹۸۵ بایت). همین خط داخل برنامه، در فایل `trust_anchors.dart` ، قرار گرفته است. شناسهٔ آن `b45a8048bd2d0314` است. فرمان `inspect` هم برای بررسی فایل‌ها از آن استفاده می‌کند.
`roster.csv`	داخلی	فهرست اعضا: نام سازمان («سازمان نمونه هم‌رسان») و دو عضو آزمون، علی رودی با `09034853204` و گوشی دوم با `09356455230` . با هر تغییر اعضا، این فایل ویرایش و `issue` دوباره اجرا می‌شود.
`issued\001-09034853204.hkb` `issued\002-09356455230.hkb`	با رمز قفل است	فایل کلید هر عضو (بخش ۹-۲). هر کدام روی گوشی همان عضو کپی و وارد شده است. بدون رمزش باز نمی‌شود، اما بهتر است بعد از وارد شدن از جاهای عمومی پاک شود.
`issued\update.hku`	فقط برای اعضا	فایل به‌روزرسانی (بخش ۹-۲-۱): دفترچهٔ فعلی بدون کلید کسی. فقط گوشی اعضای این سازمان بازش می‌کند و رمز نمی‌خواهد.
`issuance-log.csv`	داخلی	دفتر صدور پنل: هر صدور و هر تحویل با تاریخ. پنل از روی آن نشان می‌دهد چه کسی فایل قدیمی دارد.
`certificates.txt`	داخلی	زمانی که پنل ۱٫۲ فایل همهٔ اعضا را یک بار با گواهی دوباره ساخت. تحویلی که پیش از این زمان ثبت شده، «فایل بدون گواهی» حساب می‌شود.
`issued\passwords.csv`	محرمانه	رمز ۲۰ نویسه‌ای فایل کلید هر عضو. ابزار در صدور دوباره از همین فایل استفاده می‌کند تا رمز اعضای قبلی عوض نشود. فایل و رمز هر عضو باید از دو راه جدا به دستش برسند (مثلاً فایل روی فلش، رمز حضوری).

`README-FA.txt`	محرمانه	یادداشت فارسی که توضیح می‌دهد این پوشه چیست. اطلاعات آزمون دو گوشی را هم دارد: رمز ۶ رقمی برنامه، کد بازیابی، کد فعال‌سازی و رمز فایل کلید هر گوشی. فقط برای دورهٔ آزمون است و بعد از آن باید پاک شود.

توصیه برای استفادهٔ واقعی: این پوشه را به یک رایانهٔ بدون اینترنت منتقل کنید. از `authority.hka` یک نسخهٔ پشتیبان روی حافظهٔ جدا بگیرید و در جای امن نگه دارید. `authority-password.txt` و `README-FA.txt` را پاک کنید. بعد از اینکه هر عضو فایلش را وارد کرد، رمز آن را از `passwords.csv` هم بردارید، یا اگر برای صدور دوباره لازم است، کل پوشه را رمز کنید.

۱۱. پیام رمز گروهی

پیامک ارسال گروهی واقعی ندارد. اپراتور هم برای ده گیرنده، ده پیامک جدا می‌فرستد. پس هم‌رسان پیام گروه را **برای هر عضو جداگانه**، روی کانال امن دونفرهٔ همان عضو، رمز و ارسال می‌کند. همهٔ ویژگی‌های کانال دونفره، مثل کلید جدا برای هر پیام، برای گروه هم برقرار است.

- **هزینه:** هر پیام به ازای هر گیرنده یک پیامک است. برنامه این را زیر کادر نوشتن نشان می‌دهد: «به ۳ نفر · هر پیام ۳ پیامک».
- **دو نوع گروه** که سازنده انتخاب می‌کند و بعداً عوض نمی‌شود: «گفتگوی گروهی»، که پاسخ هر عضو به همه می‌رسد، و «اطلاع‌رسانی»، که پاسخ اعضا فقط به سازنده می‌رسد.
- **مشخصات گروه** (نام، نوع، فهرست اعضا) یک بستهٔ رمزشدهٔ جداست که پیش از اولین پیام و بعد از هر تغییر برای اعضا فرستاده می‌شود. فقط مشخصاتی پذیرفته می‌شود که از خود سازنده آمده و از قبلی جدیدتر باشد. پس عضو دیگری نمی‌تواند خودش را مدیر جا بزند یا عضوی اضافه کند.
- **«دیده شد»** فقط به فرستندهٔ همان پیام می‌رود. فرستنده «دیده شده ۲ از ۳» را زیر پیام می‌بیند و با نگه داشتن پیام، وضعیت هر عضو را جدا می‌بیند: در انتظار کانال امن، ارسال‌شده، تحویل‌شده، دیده‌شده یا ناموفق.
- سقف ۱۰۰ عضو است. اولین بار که دو عضو در گروه با هم حرف می‌زنند، کانال امن بینشان خودکار ساخته می‌شود.
- حذف گروه فقط از گوشی خود کاربر است و روی گوشی بقیه می‌ماند.

۱۲. دفترچهٔ تلفن مخفی

گاهی خود اینکه شما با چه کسی در تماس هستید محرمانه است، نه فقط محتوای پیام‌ها. «دفترچه مخفی» برای همین است. مخاطبی که در آن ذخیره شود، هیچ ردی بیرون از بخش امن باقی نمی‌گذارد:

- در دفترچهٔ تلفن اندروید نیست. برنامه‌های دیگری که به مخاطبین دسترسی دارند، مثل واتس‌اپ و تلگرام، آن را نمی‌بینند.
- **تماس‌ها:** اندروید هر تماس را خودش در سوابق تماس ثبت می‌کند و نمی‌شود جلویش را گرفت. هم‌رسان بلافاصله بعد از تماس آن ردیف را رمز می‌کند، به «تماس‌های مخفی» می‌برد و از سوابق اندروید پاک می‌کند.
- **پیامک‌ها:** پیامک مخاطب مخفی، رمز یا عادی، در حافظهٔ پیامک اندروید ثبت نمی‌شود و فقط داخل بخش امن ذخیره می‌شود.
- **وقتی بخش امن قفل است:** تماس ورودی از مخاطب مخفی فقط شماره را نشان می‌دهد، نه نام. تماس بی‌پاسخ فقط می‌گوید «تماس بی‌پاسخ» و شماره را هم نشان نمی‌دهد.
- **سوابق قبلی:** با مخفی شدن یک شماره، پیامک‌ها و تماس‌های قبلی آن هم از سوابق گوشی به بخش امن منتقل می‌شوند. پیام زمان‌بندی‌شده به شمارهٔ مخفی هم بی‌اثر از مسیر امن می‌رود. اگر اپراتور دربارهٔ تماس بی‌پاسخ یک شمارهٔ مخفی پیامک بدهد، آن پیامک هم به بخش امن می‌رود.
- **سازوکار:** وقتی بخش امن قفل است، برنامه کلید آن را ندارد. پس شماره‌های مخفی را فقط به شکل «برچسب» می‌شناسد: هش HMAC با کلیدی که در Android Keystore قفل است. هر اتفاقی که در این مدت بیفتد، با کلید عمومی خود بخش امن (ML-KEM-768 + X25519) مهروموم می‌شود و فقط بعد از باز شدن قفل خوانده می‌شود.

برای اینکه این قابلیت کامل کار کند، هم‌رسان باید برنامهٔ پیش‌فرض پیامک و تلفن باشد. برنامه بعد از ذخیرهٔ اولین مخاطب مخفی این را پیشنهاد می‌دهد.

۱۳. قابلیت‌های امنیتی دیگر

قابلیت	چه می‌کند
دیده شد	وقتی گیرنده گفتگو را باز می‌کند، یک رسید رمزشده برای فرستنده می‌رود و زیر پیام «دیده شد» می‌آید. یک رسید همهٔ پیام‌های تازه را پوشش می‌دهد. از منوی «پیام‌های رمز» قابل خاموش کردن است.
حذف برای هر دو	با نگه داشتن پیام خودتان، پیام از گوشی طرف مقابل هم پاک می‌شود. گیرنده فقط پیامی را پاک می‌کند که واقعاً از همان فرستنده گرفته است، پس کسی نمی‌تواند پیام‌های دیگران را پاک کند. در آزمون، پیام ۳ ثانیه بعد از گوشی دیگر هم پاک شد.
حذف پس از دیدن	فرستنده پیش از ارسال انتخاب می‌کند. در گوشی گیرنده، پیام بعد از نمایش علامت می‌خورد و با بیرون رفتن از گفتگو پاک می‌شود.
پیام زمان‌دار	فرستنده یکی از ۳۰ ثانیه، ۵ دقیقه، ۱ ساعت، ۱ روز یا ۱ هفته را انتخاب می‌کند. در گوشی گیرنده، زمان از لحظهٔ **دیده شدن** حساب می‌شود و در گوشی فرستنده از لحظهٔ **ارسال**. زیر پیام نوشته می‌شود تا چه ساعتی می‌ماند. مدت داخل بخش رمزشده است و اپراتور آن را نمی‌بیند.
انتخاب سیم‌کارت	در گوشی دوسیم‌کارته، از منوی «پیام‌های رمز» می‌شود تعیین کرد پیام رمز با کدام سیم‌کارت برود. این مشکل در آزمون پیدا شد: سیم پیش‌فرض گوشی اعتبار نداشت.
کنترل امنیت سامانه	صفحه‌ای که وضعیت امنیتی گوشی را بررسی و به زبان ساده گزارش می‌کند: روت بودن، ابزارهای نفوذ و دستکاری برنامه (مثل Frida و Xposed)، امضای رسمی برنامه، شبیه‌ساز، روشن بودن اشکال‌زدایی USB، قفل صفحهٔ گوشی، برنامه‌هایی که صفحه را می‌خوانند (دسترس‌پذیری)، تاریخ آخرین وصلهٔ امنیتی اندروید، رمزنگاری حافظه، محل نگهداری کلید بخش امن (StrongBox یا TEE) و پیش‌فرض بودن هم‌رسان برای پیامک و تماس. هر مورد با رنگ سالم، هشدار یا خطر نشان داده می‌شود.
عکس از ورود ناموفق	اگر روشن باشد، با هر ۳ رمز اشتباه پشت‌سرهم، برنامه بی‌صدا با دوربین جلو و پشت عکس می‌گیرد. عکس‌ها مهروموم و فقط داخل بخش امن نگه داشته می‌شوند. بعد از ورود موفق، صاحب گوشی گزارش «رمز برنامه سه بار پشت‌سرهم اشتباه وارد شد» را می‌بیند. پیش‌فرض خاموش است و موقع روشن کردن اجازهٔ دوربین گرفته می‌شود.
متن پوششی	فقط نسخهٔ سازمانی؛ بخش ۷-۳.
قفل برنامه و تماس (۱۴۰۵/۰۷/۲۲، در همهٔ نسخه‌ها)	
قفل خودکار	اگر برنامه بیشتر از مدت انتخابی (فوراً، ۱، ۵ یا ۳۰ دقیقه؛ پیش‌فرض ۱ دقیقه) پشت صحنه بماند، رمز برنامه دوباره خواسته می‌شود. «باز بودن» فقط در حافظهٔ برنامه است؛ هر بار که برنامه از نو اجرا شود، قفل است.
اثر انگشت یا چهره	به‌جای تایپ رمز برنامه؛ پیش‌فرض خاموش. از پنجرهٔ استاندارد اندروید (BiometricPrompt) استفاده می‌کند و هرگز رمز صفحهٔ خود گوشی را به‌جای رمز برنامه نمی‌پذیرد. فقط قفل برنامه را باز می‌کند؛ بخش امن که با خود رمز قفل شده، همچنان رمز ۶ رقمی را می‌خواهد. اگر اثر انگشت تازه‌ای به گوشی اضافه شود، کلیدی در Keystore باطل می‌شود و این گزینه خودش خاموش می‌شود.
پنهان کردن محتوای اعلان‌ها	پیش‌فرض روشن. **فقط وقتی برنامه قفل است**، اعلان پیامک و تماس بی‌پاسخ فقط می‌گوید «پیام جدید»: بدون نام، متن، عکس و دکمه. وقتی برنامه باز است اعلان‌ها کامل‌اند و اعلان‌هایی که هنوز روی صفحه مانده‌اند با قفل شدن برنامه بی‌صدا پنهان می‌شوند.
رمز برای پاسخ به تماس	پیش‌فرض خاموش. اگر روشن باشد، صفحهٔ رمز روی صفحهٔ تماس ورودی می‌آید. در حالت عادی تماس بدون رمز جواب داده می‌شود، ولی رد کردنش برنامه را باز نمی‌گذارد.

مسدود کردن تماس	رد کردن تماس‌های ناشناس، شماره‌های خارج از مخاطبین، بین‌المللی و پیش‌شماره‌های تبلیغاتی (پیش‌فرض `0942`). مخاطبان، شماره‌هایی که در ۷ روز گذشته گرفته شده‌اند و شماره‌های خدماتی هرگز مسدود نمی‌شوند. اگر دفترچهٔ تلفن خوانده نشود، هیچ تماسی رد نمی‌شود.



۱۳-۱ تنظیمات ← امنیت



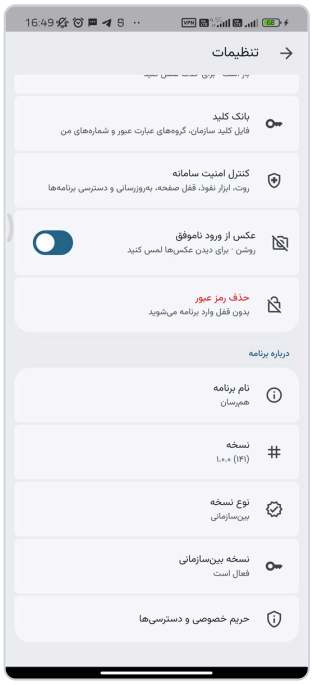
۱۳-۲ «مسدود کردن تماس»

۱۴. نقشهٔ استفاده از برنامه، با تصویر

این بخش مسیر کلی کار را با تصویر نشان می‌دهد تا معلوم شود هر قابلیت کجای برنامه است. همهٔ تصویرها، جز دو تصویر ساخت رمز و بخش امن، از دو گوشی واقعی با سیم‌کارت و شبکهٔ واقعی گرفته شده‌اند: **گوشی اول** سامسونگ Galaxy A33 با عضو «علی رودی» و **گوشی دوم** شیائومی Mi 10T با عضو «گوشی دوم». در نسخهٔ واقعی، صفحه‌های بخش امن در اسکرین‌شات سیاه درمی‌آیند. فقط برای این عکس‌ها از یک نسخهٔ موقت استفاده شد که بعد از عکس‌برداری از گوشی‌ها پاک شد. بخش‌هایی از چند تصویر که اطلاعات شخصی صاحب گوشی را داشتند بریده شده‌اند. تصویرهای گواهی عضو (۱۴۰۵/۰۷/۲۵) با همین روش از سامسونگ و یک گوشی هواوی گرفته شدند. متن پیام‌ها لاتین است، چون از رایانه تایپ شدند. راهنمای کاربر همین مسیر را مرحله به مرحله و با جزئیات کامل‌تر توضیح می‌دهد.

گام ۱. فعال کردن نسخهٔ بین‌سازمانی

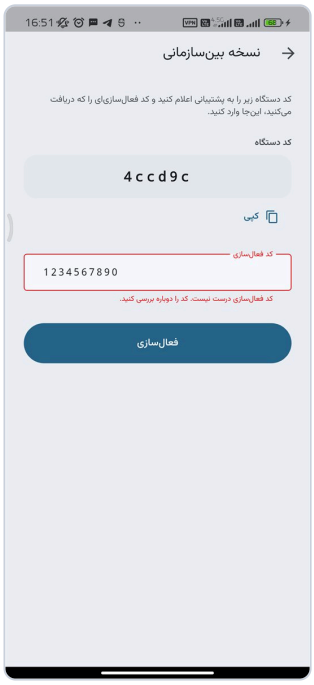
در «درباره برنامه»، ردیف «نسخه بین‌سازمانی» صفحه‌ای باز می‌کند که کد دستگاه را نشان می‌دهد. کاربر این کد را به پشتیبانی می‌دهد و کد فعال‌سازی را وارد می‌کند. کد اشتباه رد می‌شود و کد درست، قابلیت‌های امن را باز می‌کند.



۱ «درباره برنامه»



۲ کد دستگاه: 4ccd9c



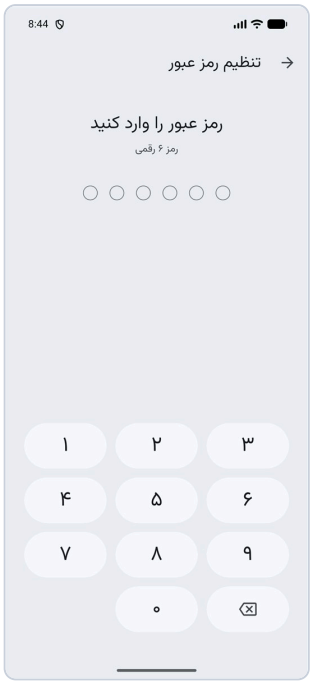
۳ کد اشتباه رد می‌شود



۴ نسخه فعال شد

گام ۲. رمز ۶ رقمی و ساختن بخش امن

نسخه‌های امن رمز ۶ رقمی می‌خواهند. اولین لمس آیکون قفل، بخش امن را با همان رمز برنامه می‌سازد. برنامه هشدار می‌دهد که فراموشی رمز یعنی از دست رفتن محتوای امن. این دو تصویر از شبیه‌ساز و نسخهٔ قبلی سند هستند.



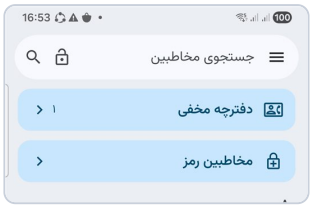
۵ رمز ۶ رقمی



۶ ساختن بخش امن



۷ قفل بسته: هیچ ردیف امنی نیست



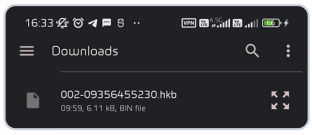
۸ قفل باز: «دفترچه مخفی» و «مخاطبین رمز»

گام ۳. وارد کردن فایل کلید

تنظیمات ← امنیت ← «بانک کلید» ← «وارد کردن فایل کلید». پنجرهٔ فایل خود اندروید باز می‌شود و کاربر فایل `.hkb` را انتخاب می‌کند. بعد رمز ۲۰ نویسه‌ای فایل را وارد می‌کند. رمز اشتباه رد می‌شود. بعد از ورود، نام سازمان و «کلید شما» دیده می‌شود.



۹ تنظیمات امنیت



۱۰ انتخاب فایل کلید



۱۱ رمز فایل کلید



۱۲ «رمز فایل کلید اشتباه است»



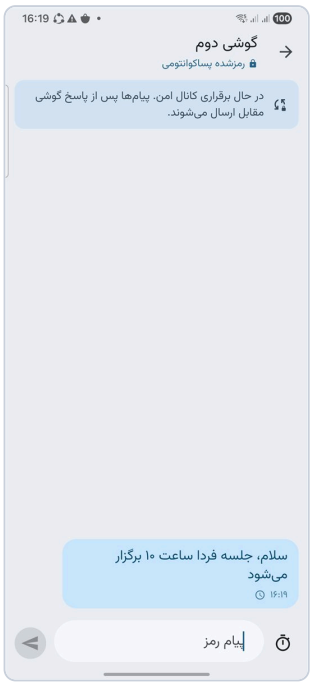
۱۳ بانک کلید: سازمان و «کلید شما»

گام ۴. اولین پیام رمز بین دو گوشی

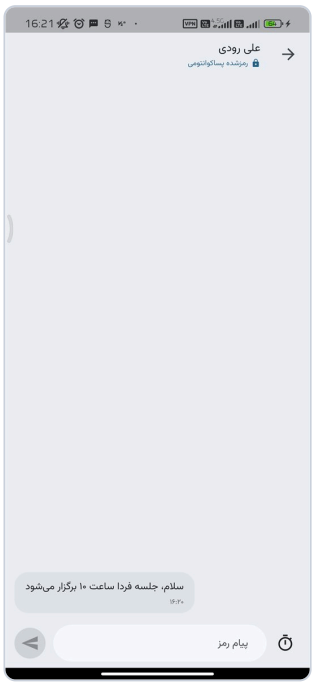
«پیام‌ها» ← «پیام‌های رمز» ← «گفتگوی رمز». اعضای دفترچه فهرست شده‌اند. به عضوی که در فهرست نیست، با نوشتن شمارهٔ همراه کاملش و تأیید «این شماره در دفترچهٔ کلید نیست» پیام داده می‌شود (ردیف دوم تصویرها). اولین پیام چند ثانیه در حالت «در حال برقراری کانال امن» می‌ماند. گوشی دوم خودکار پاسخ می‌دهد و پیام می‌رسد. وقتی گیرنده پیام را باز می‌کند، زیر پیام فرستنده «دیده شد» می‌آید.



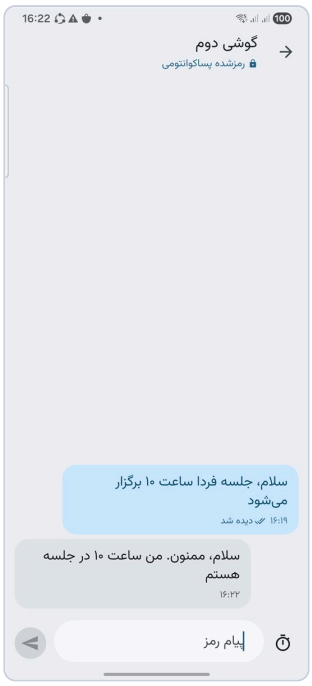
۱۴ گوشی اول: انتخاب گیرنده



۱۵ گوشی اول: برقراری کانال امن



۱۶ گوشی دوم: پیام رسید



۱۷ گوشی اول: «دیده شد» و پاسخ

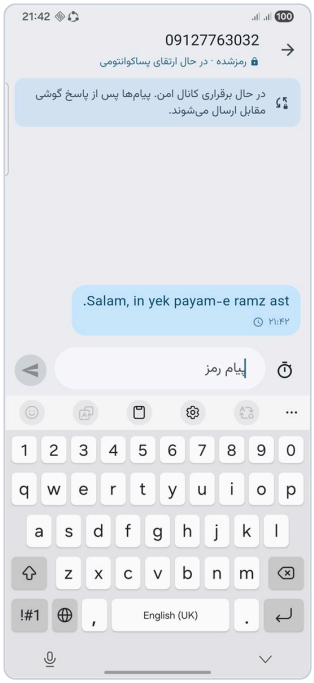
همین گام با **گواهی عضو** (۱۴۰۵/۰۷/۲۵): سامسونگی که فهرستش جز خودش کسی را نداشت، به هواوی که بعداً عضو شده بود پیام داد.



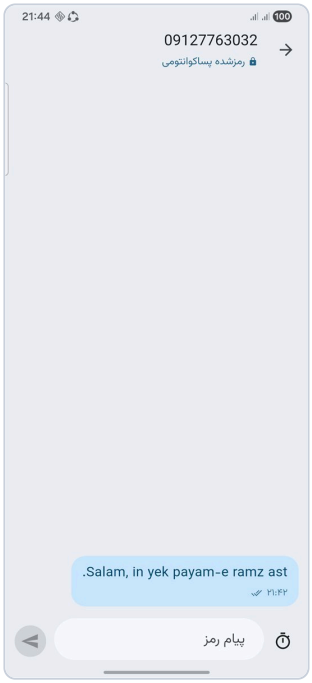
۱۷-الف شمارهٔ عضو تازه



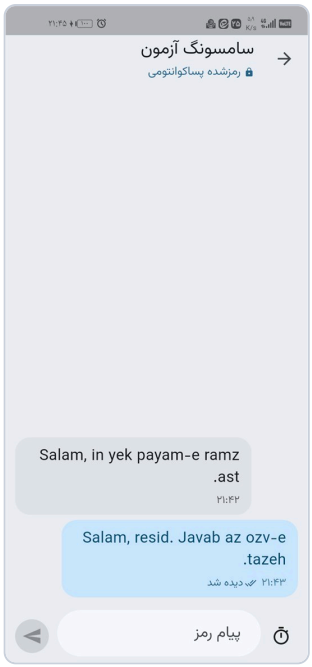
۱۷-ب «این شماره در دفترچهٔ کلید نیست»



۱۷-پ کانال ۴ تکه‌ای در راه؛ «در حال ارتقای پساکوانتومی»



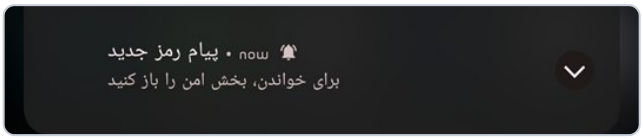
۱۷-ت بعد از ارتقا: «رمزشده پساکوانتومی»



۱۷-ث هواوی: پیام رسید، جواب و «دیده شد»

گام ۵. اعلان، زمان‌دار، حذف

اعلان پیام رمز هیچ اطلاعاتی ندارد. با دکمهٔ تایمر کنار کادر نوشتن، پیام زمان‌دار یا «پس از دیدن» می‌شود. با نگه داشتن پیام خود، «حذف برای هر دو» در دسترس است.



۱۸ گوشی دوم: اعلان بدون نام و متن



۱۹ گزینه‌های پاک شدن خودکار



۲۰ پیام زمان‌دار: «تا ۱۶:۴۶»

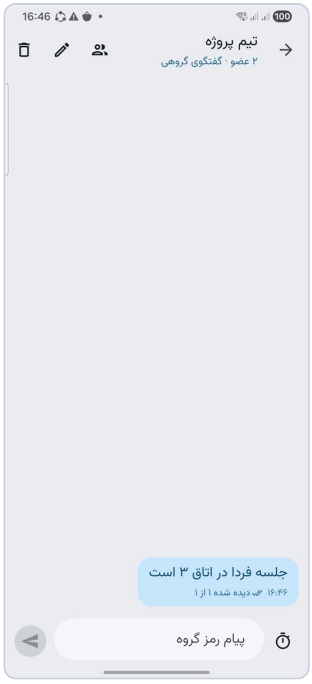


۲۱ «حذف برای هر دو»

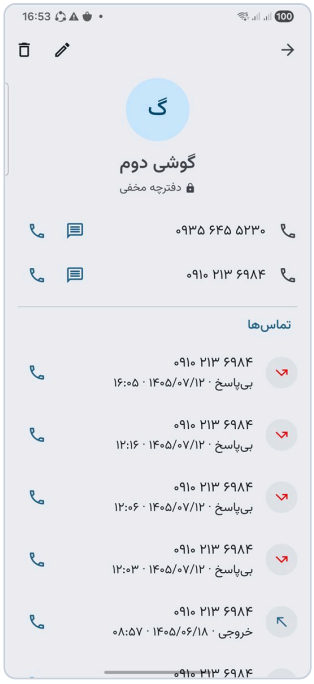
گام ۶. گروه رمز، دفترچهٔ مخفی و ابزارهای امنیتی



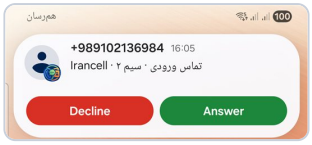
۲۲ ساختن گروه رمز



۲۳ پیام گروه: «دیده شده ۱ از ۱»



۲۴ مخاطب مخفی و تماس‌هایش



۲۵ تماس مخاطب مخفی با قفل بسته: فقط شماره



۲۶ کنترل امنیت سامانه



۲۷ عکس‌های ورود ناموفق

۱۵. تطبیق با پیوست فنی

ردیف	قابلیت	وضعیت	توضیح
۱	کد فعال‌سازی	انجام شد	قالب نرم‌افزار قبلی؛ بخش ۳
۳	آیکون قفل برای نمایش یا پنهان کردن بخش‌های رمز و مخفی	انجام شد	در همهٔ زبانه‌ها
۱۱	رمزنگاری پیامک، دفترچهٔ مخفی و سوابق تماس بدون ثبت در سیستم‌عامل	انجام شد	بخش‌های ۶ و ۱۲
۱۲	رمزنگاری بانک اطلاعاتی برنامه	بخشی	بخش امن کامل رمز است؛ پیامک و مخاطبین عادی نه (بخش ۱۷)
۱۳	تغییر کلید با هر پیام و هر مخاطب	انجام شد	بخش ۶-۳
۱۴	پیام رمز گروهی	انجام شد	بخش ۱۱
۱۶	پیام رمز زمان‌دار	انجام شد	پاک شدن خودکار پس از مدت انتخابی؛ بخش ۱۳
۱۹	حذف دوطرفه	انجام شد	یک‌به‌یک و گروه
۲۰	حذف خودکار پیام دریافتی پس از دیدن	انجام شد	به انتخاب فرستنده برای هر پیام
۲۲	عدم امکان کپی و تصویربرداری	انجام شد	بخش ۸
۲۵	ارسال موقعیت و پاک‌سازی گوشی با پیامک خاص	انجام نشد	نیاز به تصمیم؛ بخش ۱۷
۲۹	کنترل امنیت سامانه	انجام شد	بخش ۱۳
۳۰	اطلاع فرستنده از رؤیت	انجام شد	«دیده شد»؛ یک‌به‌یک و گروه
۳۱	تبدیل متن رمز به متن پوششی (فقط سازمانی)	انجام شد	فارسی و انگلیسی؛ بخش ۷-۳
۳۲	عکس‌برداری پنهان پس از ۳ رمز اشتباه	انجام شد	هر دو دوربین؛ بخش ۱۳
۳۳	رمزنگاری پساکوانتومی	انجام شد	الگوریتم‌های استاندارد NIST؛ بخش ۵. از ۱۴۰۵/۰۷/۲۵ کانال امن اول کلاسیک (۴ تکه) ساخته و چند ثانیه بعد در پس‌زمینه پساکوانتومی می‌شود (بخش ۶-۲)
۳۵	دفترچهٔ تلفن اختصاصی رمزشده با پیامک و تماس بدون ثبت در سیستم‌عامل	انجام شد	بخش ۱۲
۳۶	گروه یا فیلتر پیش‌فرض برای مخاطبین و پیامک‌های رمز	بخشی	«پیام‌های رمز»، «دفترچه مخفی» و «مخاطبین رمز» جدا هستند

۱۶. آزمون‌ها

- **به‌روزرسانی ۱۴۰۵/۰۷/۲۵:** ۱۳۸ آزمون JVM سمت اندروید، ۷۴۷ آزمون Dart، ۲۵ آزمون ابزار مرجع و ۱۴ آزمون پنل، همه موفق؛ flutter analyze بدون ایراد. تازه‌ها: ۱۵ آزمون گواهی و کانال ۴ تکه‌ای (اندازه و امضای گواهی، فقط شمارهٔ همراه، گواهی داخل فایل کلید، ۲ تکه در هر جهت، درخواست یا جواب از بیرون سازمان، جواب با گواهی شخص دیگر، بستهٔ دستکاری‌شده، ارتقای پس‌زمینه و جایگزینی کلید در آن)، ۵ آزمون موتور پیام با گواهی (پیام اول و ارتقا، عضوی که در دفترچهٔ هیچ‌کس نیست،

درخواست بدون امضای مرجع، رد گواهی نسل قدیمی گوشی گم‌شده، گم شدن جواب ارتقا؛ و عنوان «پساکوانتومی» فقط بعد از ارتقا)، بردار آزمون مشترک شناسهٔ کلید گواهی، و خودآزمایی نسخهٔ نصب‌شدهٔ پنل ۱٫۲ (کانال گواهی بین دو عضو).

آزمون دو گوشی واقعی با سناریوی منتور: سامسونگ A33 (سیم ۲، `09034853204`) و هواوی (`09127763032`)، هر دو از نو نصب‌شده، با مرجع آزمایشی. سامسونگ فایلی گرفت که فهرستش فقط خودش را داشت و هواوی را بعداً به سازمان اضافه کردیم و فقط فایل خودش را به او دادیم. نتیجه: سامسونگ با نوشتن شمارهٔ هواوی پیام داد: درخواست ۲ تکه، جواب ۲ تکه، پیام ۷ ثانیه بعد از «ارسال» رفت و ارتقای پساکوانتومی (۱۱ + ۱۰ + ۱ تکه) حدود ۲۵ ثانیه بعد روی هر دو گوشی کامل شد. هواوی نام «سامسونگ آزمون» را از دفترچه‌اش دید و جواب داد (۱ تکه، با «دیده شد»). در جهت عکس هم، با گفتگوی تازه‌ای که هواوی شروع کرد، همین نتیجه به دست آمد.

اشکال‌هایی که در این آزمون پیدا و همان روز رفع شد: (۱) عنوان گفتگو پیش از تمام شدن ارتقا هم «رمزشده پساکوانتومی» می‌گفت؛ حالا «رمزشده · در حال ارتقای پساکوانتومی». (۲) گوشی‌ای که فهرستش جز خودش کسی را نداشت، می‌گفت «هنوز دفترچه کلیدی با کلید شما وارد نشده است»؛ حالا می‌گوید شمارهٔ عضو را وارد کنید. (۳) توضیح تنظیم «پنهان کردن محتوای اعلان‌ها» نمی‌گفت که فقط در حالت قفل است. (۴) وقتی جواب کانال امن می‌رسید، اعلان «پیام رمز شما آماده ارسال است · برای ارسال، بخش امن را باز کنید» یک لحظه با صدا بالا می‌آمد، حتی وقتی کاربر همان لحظه داخل گفتگو بود. حالا وقتی برنامه روی صفحه و بخش امن باز است این اعلان نمی‌آید و پیام خودش می‌رود (روی سامسونگ آزموده شد). اعلان «پیام رمز جدید» برای پیام واقعی مثل قبل است.

مشاهده: اولین درخواست از سیم ۱ سامسونگ (که شمارهٔ دیگری است) با وجود گزارش ارسال موفق هیچ‌وقت به هواوی نرسید. بعد از انتخاب سیم ۲ در منوی «پیام‌های رمز»، همه چیز در چند ثانیه رسید.

- **به‌روزرسانی ۱۴۰۵/۰۷/۱۵:** ۱۰۸ آزمون JVM و ۶۹۸ آزمون Dart، همه موفق (اعداد پایین مربوط به ۱۴۰۵/۰۷/۱۲ است). تازه‌ها: فایل به‌روزرسانی (باز شدن فقط برای همان سازمان، جعل و جابه‌جایی دفترچه)، انتقال گفتگو به کلید تازهٔ همکار و قطع گوشی گم‌شده، و ۳۵ آزمون پنل صدور (دفتر صدور، گوشی گم شد، ویرایش، حذف، صدور «همه یا هیچ»، و فشار دادن دکمهٔ واقعی پنجرهٔ تأیید). روی سامسونگ واقعی: فایل به‌روزرسانی مرجع واقعی بدون رمز وارد شد («دفترچه کلید به‌روز شد»، کلید عضو حفظ شد)، دوباره وارد کردنش «قبلاً وارد شده است» گفت، و بعد از آن پیام رمز با همان کانال قبلی فرستاده شد.
- **۹۸ آزمون خودکار سمت اندروید (JVM):** بردارهای رسمی NIST برای ML-KEM-768 و ML-DSA-65؛ بردارهای RFC 7748، 8032، 5869 و 9106؛ حملهٔ مرد میانی، دستکاری، تکرار و بی‌ترتیبی؛ پیام زمان‌دار؛ متن پوششی؛ و بردارهای طلایی که قالب پیام، فایل کلید و مهروموم را قفل می‌کنند.
- **۶۷۵ آزمون خودکار سمت برنامه (Dart):** موتور پیام با دو و سه گوشی مجازی، گروه‌ها و جعل مشخصات گروه، پیام زمان‌دار، دوسیم‌کارته‌ها، ارتقای پایگاه‌داده، بانک کلید، دفترچهٔ مخفی و کنترل امنیت. همه موفق‌اند و بررسی خودکار کیفیت کد (flutter analyze) هیچ ایرادی نمی‌گیرد.
- **آزمون روی شبکهٔ واقعی (۱۴۰۵/۰۷/۱۲):** دو گوشی واقعی با سیم‌کارت و اپراتور واقعی، کلیدهای صادرشده از مرجع واقعی. موارد آزموده‌شده: فعال‌سازی، وارد کردن فایل کلید، ساختن کانال امن (۵۰ ثانیه)، پیام و پاسخ (۳ تا ۶ ثانیه)، «دیده شد»، پیام زمان‌دار، حذف پس از دیدن، حذف برای هر دو، گروه رمز، دفترچهٔ مخفی (تماس ورودی، تماس بی‌پاسخ، پیامک)، عکس ورود ناموفق، کنترل امنیت سامانه، قفل و باز شدن بخش امن و به‌روزرسانی برنامه بدون از دست رفتن کانال‌ها.
- **اشکال‌هایی که روی گوشی واقعی پیدا و رفع شد:** (۱) پاسخ گوشی دوسیم‌کارته از سیم دیگرش می‌آمد و شناخته نمی‌شد؛ حالا فرستنده با شناسهٔ کلید شناخته می‌شود، نه شماره. (۲) پیام رمز از سیم پیش‌فرضی می‌رفت که اعتبار نداشت؛ گزینهٔ انتخاب سیم‌کارت اضافه شد. (۳) بعد از بازگشت به برنامه و وارد کردن رمز، صفحهٔ گفتگو خالی می‌ماند. (۴) عنوان گفتگو به‌جای نام، شماره را نشان می‌داد. (۵) چند متن صفحهٔ کنترل امنیت گنگ بود.

- **یک مشاهدهٔ شبکه:** یکی از پیامک‌ها ۱۷ دقیقه در شبکهٔ اپراتور ماند و بعد رسید. یک بار هم در آزمون‌های قبلی، شیائومی یک درخواست ۱۰ قطعه‌ای کانال امن را خودش مسدود کرد و در چهار تکرار بعدی این اتفاق نیفتاد. هر دو مورد خارج از برنامه‌اند. برنامه پیام دیررسیده را درست نشان داد.

۱۷. محدودیت‌ها و تصمیم‌های باز

تصمیم‌هایی که برای پیش رفتن کار گرفته شد

این موارد در نسخهٔ قبلی سند به‌صورت پرسش آمده بودند. برای اینکه کار متوقف نشود، به تصمیم مالک پروژه به این شکل پیاده شدند و قابل تغییرند.

موضوع	آنچه پیاده شد
معنای «پیام زمان‌دار»	پیامی که پس از مدت انتخابی خودبه‌خود پاک می‌شود (برای ارسال زمان‌بندی‌شده، برنامه از قبل قابلیت جدا دارد).
معنای «کنترل امنیت سامانه»	بررسی وضعیت امنیتی گوشی و گزارش آن (بخش ۱۳).
شکل متن پوششی	کلمه‌های فارسی یا انگلیسی از یک فهرست ثابت، فقط برای پیام و رسید.
مرجع کلید	یک مرجع واقعی ساخته و کلید عمومی‌اش داخل برنامه گذاشته شد (بخش ۱۰). برنامه می‌تواند هم‌زمان چند مرجع را بپذیرد.
کمبودهای دفترچهٔ مخفی	هر سه رفع شد: پیام زمان‌بندی‌شده، پیامک اپراتور دربارهٔ تماس بی‌پاسخ، و پیشنهاد پیش‌فرض شدن برنامه.
رسیدن به عضو تازه بدون فایل برای همه (۱۴۰۵/۰۷/۲۵)	گواهی عضو (گزینهٔ «ب»)، نه گروه عبارت عبور (گزینهٔ «الف»)؛ بخش ۹-۷.
تعداد پیامک اولین تماس	«باید خیلی کمتر شود، حتی به بهای پایین رفتن امنیت»: ۴ تکه، کلاسیک؛ لایهٔ پساکوانتومی «بعداً در پس‌زمینه». گواهی فقط با Ed25519.
انقضا و ابطال گواهی	«نیازی به انقضا نیست؛ بیرون کردن عضو را بیخیال». گواهی تاریخ انقضا ندارد و باطل نمی‌شود. **پیامد:** عضوی که از سازمان حذف شده، با فایل کلیدش هنوز به اعضا پیام رمز می‌دهد و پیام می‌گیرد. گوشی گم‌شده هم برای گوشی‌هایی که هنوز گواهی نسل تازهٔ صاحبش را ندیده‌اند معتبر می‌ماند.

محدودیت‌های روش گواهی که باید بدانید

- **فایل بدون گواهی:** پشتیبانی نمی‌شود. گوشی‌ای که چنین فایلی دارد به درخواست گواهی جواب نمی‌دهد. چون برنامه هنوز منتشر نشده، همهٔ اعضا از اول فایل پنل ۱٫۲ می‌گیرند و این حالت پیش نمی‌آید (تصمیم مالک پروژه، ۱۴۰۵/۰۷/۲۵).
- **چند مرجع:** گوشی‌ای که فایل کلید دو مرجع (دو سازمان) را دارد، به درخواست گواهی با گواهی اولین مرجع جواب می‌دهد. اگر درخواست‌دهنده فقط به مرجع دوم اعتماد کند، کانال ساخته نمی‌شود.
- **شمارهٔ عضویت:** گواهی فقط برای اولین شمارهٔ همراه عضو است. در گوشی دوسیم‌کارته، پیام رمز باید از سیم همان شماره برود (منوی «پیام‌های رمز»).
- **پیام‌های پیش از ارتقا** کلاسیک‌اند (بخش ۶-۵).

موضوع‌هایی که هنوز تصمیم شما را لازم دارند

۱. **ردیف ۲۵، فرمان پیامکی برای ارسال موقعیت و پاک کردن گوشی:** پیاده نشده است. این قابلیت اگر درست طراحی نشود، به هر کس که پیامک خاص را بداند اجازهٔ پاک کردن گوشی یا ردیابی صاحبش را می‌دهد. پیشنهاد ما این است که فقط با پیام رمز از یک عضو تعیین‌شده در دفترچهٔ سازمان کار کند و پیش از اجرا تأیید بخواهد. پیش از ساخت، تأیید شما لازم است.

۲. **امنیت کد فعال‌سازی:** قالب فعلی با مهندسی معکوس قابل جعل و غیرقابل باطل کردن است (بخش ۳). جایگزین: کد امضاشده با طول ۲۰ تا ۳۰ نویسه که به تغییر برنامهٔ ویندوزی نیاز دارد.

۳. **نگهداری کلید نزد مرجع:** مرجع می‌تواند کلید خصوصی هر عضو را بازسازی کند. جایگزین این است که هر عضو کلیدش را روی گوشی خودش بسازد و مرجع فقط کلید عمومی او را امضا کند. در این حالت ثبت‌نام اعضا چند مرحلهٔ بیشتر دارد.

۴. **محافظت پساکوانتومی در برابر سرقت هم‌زمان کلیدها:** حدود ۲۰ قطعه پیامک به هر کانال امن اضافه می‌کند (بخش ۶-۵). لازم است؟ اگر لازم باشد، حالا می‌تواند مثل ارتقای فعلی در پس‌زمینه برود و کسی منتظرش نماند.

۵. **ردیف ۱۲:** آیا پیامک‌ها و مخاطبین عادی هم باید در پایگاه‌دادهٔ رمزشده باشند؟ این محتوا در هر صورت در حافظهٔ خود اندروید هم وجود دارد.

۶. **فراموشی رمز:** آیا از بین رفتن محتوای امن بدون هیچ راه بازیابی مورد قبول است؟

۷. **گروه رمز و گوشی گم‌شده:** بعد از «گوشی گم شد»، گفتگوی دونفره خودش به کلید تازه می‌رود و پیام‌های گروه هم از همان کانال می‌روند، ولی تعریف گروه تا ویرایش بعدی‌اش هنوز شناسهٔ کلید قبلی آن عضو را دارد. سازندهٔ گروه با یک ویرایش گروه آن را تازه می‌کند. خودکار کردن این کار به تصمیم شما بستگی دارد.

۸. **آزمون کد فعال‌سازی با برنامهٔ ویندوزی شما:** برای کد دستگاه `b60966` باید `9c4a48e93a` به دست آید.

۱۸. واژه‌نامه

اصطلاح	معنی
AES-256-GCM	رمز متقارن استاندارد با کلید ۲۵۶ بیتی. حالت GCM دستکاری را هم تشخیص می‌دهد.
ANDROID_ID	شناسهٔ ۱۶ نویسه‌ای که اندروید به هر برنامه روی هر گوشی می‌دهد. پایهٔ کد دستگاه است.
APK	فایل نصبی برنامهٔ اندروید.
Argon2id	الگوریتمی که رمز تایپ‌شده را به کلید تبدیل می‌کند و حدس زدن رمز را عمداً گران می‌کند.
Base64	روشی برای نوشتن داده‌های دودویی با حروف و ارقام لاتین تا در پیامک جا شوند.
BLAKE3، SHA-256	توابع هش: اثر انگشت کوتاه و یکتای داده.
FLAG_SECURE	تنظیم اندروید که اسکرین‌شات و فیلم‌برداری از صفحه را سیاه می‌کند.
HKDF، HMAC	روش‌های استاندارد ساختن کلیدهای جدا از یک راز.
ML-KEM، ML-DSA	الگوریتم‌های پساکوانتومی استاندارد NIST برای توافق کلید و امضا.
nonce	عددی که برای هر بار رمز کردن فقط یک بار به کار می‌رود.
PBKDF2	الگوریتم قدیمی‌تر تبدیل رمز به کلید که در بخش امن به کار رفته است.
ratchet (زنجیرهٔ کلید)	زنجیره‌ای که با هر پیام یک قدم جلو می‌رود و برای هر پیام کلید تازه می‌سازد.
salt (نمک)	عدد تصادفی که کنار رمز گذاشته می‌شود تا رمزهای یکسان کلید یکسان نسازند.
seed	عدد تصادفی کوتاهی که یک کلید کامل از آن ساخته می‌شود.
SQLCipher	پایگاه‌دادهٔ رمزشده‌ای که محتوای بخش امن در آن است.
TEE، StrongBox، Keystore	بخش‌های سخت‌افزاری امن گوشی که کلید داخلشان ساخته می‌شود و هرگز بیرون نمی‌آید.
X25519، Ed25519	الگوریتم‌های کلاسیک و آزمودهٔ توافق کلید و امضا بر پایهٔ منحنی بیضوی.
بانک کلید	بخشی از برنامه که کلید سازمان‌ها و گروه‌ها را نگه می‌دارد.
بخش امن	قسمت قفل‌دار برنامه که همهٔ محتوای محرمانه در آن است.
بردار طلایی	یک ورودی و خروجی ثابت در آزمون‌ها که تغییر ناخواستهٔ قالب را آشکار می‌کند.
پساکوانتومی	مقاوم در برابر کامپیوتر کوانتومی.
ترکیبی (hybrid)	به کار بردن هم‌زمان یک الگوریتم کلاسیک و یک الگوریتم پساکوانتومی، طوری که شکستن یکی کافی نباشد.
دفترچهٔ سازمان	فهرست امضاشدهٔ اعضا و کلیدهای عمومی‌شان.
شناسهٔ کلید	۸ بایت اول هش کلید عمومی یک نفر که در بسته‌ها به‌جای خود کلید به کار می‌رود.
فایل کلید (`.hkb`)	فایل رمزدار هر عضو، شامل دفترچهٔ سازمان، کلید خصوصی او و (از پنل ۱٫۲) گواهی عضو او.
کانال امن	کلید مشترکی که دو نفر یک بار با تبادل دو بسته می‌سازند.
گواهی عضو	امضای ۱۰۳ بایتی مرجع روی شمارهٔ همراه، نسل و کلید یک عضو؛ عضو را بدون فهرست به طرف مقابل معرفی می‌کند.
ارتقای پساکوانتومی	سه بستهٔ کنترلی که بعد از ساخته شدن کانال گواهی، در پس‌زمینه یک راز ML-KEM به کانال اضافه می‌کنند.

کد دستگاه، کد فعال‌سازی	کد ۶ نویسه‌ای هر گوشی و کد ۱۰ نویسه‌ای که نسخهٔ بین‌سازمانی را روی آن باز می‌کند.
مرجع کلید	شخص یا واحدی که با ابزار ویندوزی کلید اعضا را صادر و امضا می‌کند.
متن پوششی	شکل ظاهری دیگری از پیام رمز که شبیه کلمه‌های عادی است (فقط سازمانی).
مهروموم (SealedBox)	رمز کردن با کلید عمومی بخش امن، طوری که فقط بعد از باز شدن قفل خوانده شود.